



Taller 1: Control de Acceso en Entornos Virtuales Linux

Marcos David Escobar Vela

Stefany Maricela Díaz Antun

Diego Mateo Sosa Flores

Universidad de las Fuerzas Armadas ESPE

Carrera de Software

Ingeniería Seguridad del Software

Junio 2026

Contents

Glosario de Términos	5
1 Resumen	6
2 Objetivos de aprendizaje	7
3 Topología de prueba	7
4 Marco Teórico	8
4.1 Control de Acceso	8
4.2 Control de Acceso Discrecional (DAC)	9
4.2.1 Permisos en Linux: chmod y chown	9
4.3 Control de Acceso Basado en Roles (RBAC)	9
4.4 Monitoreo de Accesos y Auditoría en Linux	10
5 Desarrollo	11
5.1 Fase 1: Configuración Inicial del Entorno	11
5.2 Fase 2: Control de Acceso Discrecional (DAC) en Ubuntu Desktop	12
5.2.1 Creación de Usuarios	12
5.2.2 Creación del Archivo y Asignación de Permisos	13
5.2.3 Verificación de Denegación de Acceso a usertwo	14
5.3 Fase 3: Control de Acceso Basado en Roles (RBAC) en Metasploitable 2	15
5.3.1 Creación de Grupos y Usuarios	15
5.3.2 Creación del Directorio Protegido por Rol	16
5.3.3 Verificación de Denegación de Acceso a userthree	17
5.4 Fase 4: Simulación de Ataque desde Kali Linux	18
5.5 Fase 5: Monitoreo y Auditoría en Metasploitable 2	20
6 Actividad Extra: Diseño e Implementación de un Escenario de Control de Acceso	21
6.1 Descripción del Escenario	21

6.2	Definición de Usuarios y Roles	22
6.3	Aplicación de los Modelos de Control de Acceso	22
6.3.1	Creación de Usuarios	22
6.3.2	Creación del Directorio y del Archivo Confidencial	23
6.3.3	Asignación de Propietario	24
6.3.4	Configuración de Permisos (DAC)	24
6.3.5	Creación de Grupos (RBAC)	25
6.3.6	Asignación de Usuarios a los Grupos	26
6.4	Pruebas de Funcionamiento	26
6.4.1	Acceso de un Usuario Autorizado	26
6.4.2	Acceso de un Usuario sin Permisos	27
6.5	Tabla Resumen de Permisos	28
6.6	Análisis	28
6.6.1	¿Qué ventajas ofrece DAC en este escenario?	28
6.6.2	¿Qué ventajas ofrece RBAC?	28
6.6.3	¿Qué modelo se recomendaría implementar en una organización real y por qué?	29
6.6.4	¿Qué vulnerabilidades podrían existir si los permisos estuvieran mal configurados?	29
7	Conclusiones	29
8	Recomendaciones	30

List of Figures

1	Topología del entorno virtualizado: Ubuntu Desktop, Metasploitable 2 y Kali Linux interconectados en una red interna del hipervisor.	8
2	Resultado del comando <code>ping</code> entre los nodos. Los paquetes ICMP se reciben sin pérdidas, lo que confirma la conectividad de la red interna.	11

- 3 Creación de `userone` y `usertwo` con `adduser`. El sistema solicita la contraseña y los datos opcionales de cada usuario antes de confirmar la creación de su directorio personal. 13
- 4 Salida de `ls -l` con los permisos `-rwx----` sobre `data.txt`. El propietario es `userone` y ningún otro usuario tiene permisos asignados sobre el archivo; un intento de lectura directa por parte de un usuario no propietario produce el mensaje `Permission denied`, y solo con `sudo` se accede al listado. 14
- 5 Creación de los grupos `admin` y usuarios, creación de los usuarios `admin1` y `userthree`, y asignación de cada usuario a su grupo correspondiente con `usermod -aG`. 16
- 6 Salida de `ls -ld /admin-dir` con los permisos `drwxrwx--` y propietario de grupo `admin`. Solo los miembros del grupo `admin` tienen acceso al directorio. 17
- 7 Mensaje `Permission denied` producido al intentar acceder a `/admin-dir` como `userthree`. El sistema aplica correctamente la política RBAC: solo los miembros del grupo `admin` pueden acceder al directorio protegido. 18
- 8 Conexión SSH desde Kali Linux como `userthree` hacia Metasploitable 2. La sesión SSH se establece, pero el intento de listar `/admin-dir` es denegado por el sistema con el mensaje `Permission denied`. 19
- 9 Conexión SSH desde Kali Linux como `admin1` y acceso exitoso al directorio `/admin-dir`. El rol `admin` mantiene sus privilegios incluso en sesiones remotas, lo que valida la robustez del modelo RBAC implementado. 20
- 10 Revisión de `/var/log/auth.log` filtrada con `grep "ssh"` y salida del comando `last`. En el historial de sesiones se identifican las conexiones de `userthree` y `admin1` desde la IP de Kali Linux (192.168.200.50), con sus respectivas marcas de tiempo y duración de sesión. 21

11	Creación de los usuarios <code>admintelecom</code> , <code>supervisor</code> , <code>analista1</code> e invitado con <code>useradd -m</code> y asignación de sus respectivas contraseñas mediante <code>passwd</code>	23
12	Creación del directorio <code>/datos_empresa</code> y del archivo <code>clientes.txt</code> en su interior, verificada con <code>ls</code>	24
13	Asignación de <code>admintelecom</code> como propietario (usuario y grupo) del archivo confidencial <code>clientes.txt</code> con <code>chown</code>	24
14	Salida de <code>ls -l</code> con la cadena de permisos <code>-rw----</code> sobre <code>clientes.txt</code> . Únicamente <code>admintelecom</code> puede leer y modificar el archivo.	25
15	Creación de los grupos <code>administradores</code> y <code>analistas</code> con <code>groupadd</code> , según los roles definidos en la Tabla 2.	25
16	Asignación de <code>admintelecom</code> y <code>supervisor</code> al grupo <code>administradores</code> , y de <code>analista1</code> al grupo <code>analistas</code> , con <code>usermod -aG</code>	26
17	Acceso autorizado de <code>admintelecom</code> al archivo <code>clientes.txt</code> . El usuario propietario lee el contenido del archivo sin restricciones.	27
18	Mensaje <code>Permiso denegado</code> al intentar leer <code>clientes.txt</code> como <code>analista1</code> . El permiso <code>600</code> impide el acceso a cualquier usuario distinto del propietario.	27

List of Tables

2	Clasificación de los usuarios de la empresa de telecomunicaciones según su rol.	22
3	Resumen de permisos asignados en el escenario de la empresa de telecomunicaciones.	28

Glosario de Términos

Acrónimo	Definición
ACL	<i>Access Control List</i> (Lista de Control de Acceso). Estructura que asocia a cada objeto del sistema la lista de sujetos autorizados y los permisos concedidos a cada uno.
ABAC	<i>Attribute-Based Access Control</i> . Modelo de control de acceso en el que las decisiones se basan en atributos del sujeto, el objeto y el entorno, descrito en la guía NIST SP 800-162.
DAC	<i>Discretionary Access Control</i> (Control de Acceso Discrecional). Modelo en el que el propietario de un recurso decide de forma autónoma qué otros sujetos pueden acceder a él; es el modelo nativo de los permisos de archivo en GNU/Linux.
GID	<i>Group Identifier</i> . Identificador numérico que el sistema GNU/Linux asigna a cada grupo y que determina la pertenencia a los roles en el modelo RBAC.
ICMP	<i>Internet Control Message Protocol</i> . Protocolo empleado por la utilidad <code>ping</code> para verificar la conectividad entre los nodos de la red interna del laboratorio.
MAC	<i>Mandatory Access Control</i> (Control de Acceso Obligatorio). Modelo en el que las políticas de acceso las impone el sistema y no el propietario del recurso; en GNU/Linux lo implementa SELinux.
NIST	<i>National Institute of Standards and Technology</i> . Instituto estadounidense que publica guías de control de acceso, como la SP 800-162 citada en este taller.
RBAC	<i>Role-Based Access Control</i> (Control de Acceso Basado en Roles). Modelo en el que los permisos se asignan a roles (grupos) y los usuarios los heredan al pertenecer a dichos roles.
SELinux	<i>Security-Enhanced Linux</i> . Módulo de seguridad del kernel que añade una capa de control de acceso obligatorio (MAC) superpuesta a los permisos discrecionales del sistema.
SSH	<i>Secure Shell</i> . Protocolo de red para acceso remoto seguro, empleado en el taller para simular accesos no autorizados desde Kali Linux hacia Metasploitable 2.
UID	<i>User Identifier</i> . Identificador numérico que el sistema GNU/Linux asigna a cada usuario y sobre el que se evalúan los permisos del propietario en el modelo DAC.

Resumen

Este taller desarrolló la implementación y verificación de mecanismos de control de acceso en entornos GNU/Linux virtualizados. El trabajo cubrió dos modelos: el Control de Acceso Discrecional (DAC) y el Control de Acceso Basado en Roles (RBAC). En Ubuntu Desktop se configuró DAC sobre un archivo sensible con el permiso octal 700 a través de `chmod` y `chown`, y se comprobó la denegación de acceso a un usuario no autorizado. En Metasploitable 2 se implementó RBAC con grupos que representan roles organizacionales y se protegió un directorio con el permiso 770. La validación del acceso se realizó de forma bidireccional, con un usuario autorizado y otro sin permisos. Después se simuló, desde Kali Linux y por SSH, el intento de acceso no autorizado a los recursos protegidos, y se analizaron los registros de auditoría de `/var/log/auth.log` para comprobar la trazabilidad nativa del sistema. Por último, se diseñó un escenario de control de acceso para una empresa de telecomunicaciones, con usuarios, roles y permisos definidos bajo el principio de mínimo privilegio.

Palabras clave: control de acceso, DAC, RBAC, GNU/Linux, mínimo privilegio, permisos, auditoría.

Objetivos de aprendizaje

- El estudiante aprendió a configurar e implementar mecanismos de Control de Acceso Discrecional (DAC) y Control de Acceso Basado en Roles (RBAC) en entornos GNU/Linux, con comandos de gestión de usuarios, grupos y permisos como `chmod`, `chown` y `usermod`, para proteger recursos sensibles en escenarios organizacionales reales.
- Se aprendió a simular y detectar intentos de acceso no autorizado en un entorno virtualizado con Kali Linux y Metasploitable 2, a través del análisis de los registros de auditoría del sistema (`/var/log/auth.log`), para identificar actividad maliciosa y reforzar las políticas de control de acceso configuradas.
- Con el desarrollo de esta práctica se diseñó una política de control de acceso para un escenario organizacional real, con usuarios, roles y permisos definidos bajo los modelos DAC y RBAC. Las decisiones de seguridad adoptadas se justificaron con base en los principios de mínimo privilegio, separación de funciones e integridad de la información.

Topología de prueba

Para el desarrollo de este taller se empleó un entorno virtualizado compuesto por tres nodos interconectados en una red interna del hipervisor: **Ubuntu Desktop**, donde se configuró el modelo DAC y sobre el que SELinux aporta una capa adicional de control de acceso obligatorio (MAC); **Metasploitable 2**, que opera como servidor objetivo en el que se implementó el modelo RBAC; y **Kali Linux**, utilizado como máquina atacante para simular accesos no autorizados a través de SSH. La red interna permitió reproducir un escenario realista sin exposición a redes externas (Whitman & Mattord, 2018).

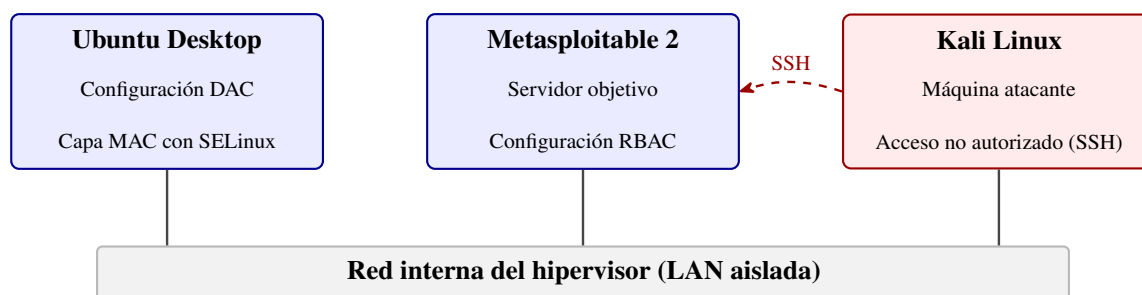


Figure 1

Topología del entorno virtualizado: Ubuntu Desktop, Metasploitable 2 y Kali Linux interconectados en una red interna del hipervisor.

Como se aprecia en la Figura 1, los tres nodos operan bajo la misma subred interna del hipervisor. Esta configuración garantiza que las pruebas de acceso no autorizado desde Kali Linux hacia Metasploitable 2 se realicen en condiciones controladas, reproducibles y sin impacto sobre redes externas.

Marco Teórico

Control de Acceso

El control de acceso es el mecanismo de seguridad que determina qué sujetos (usuarios, procesos o sistemas) pueden interactuar con qué objetos (archivos, directorios, servicios o dispositivos) y en qué condiciones. Según Whitman and Mattord (2018), “el control de acceso es el conjunto de controles que regulan cómo los sistemas determinan quién puede usar un recurso específico, cuándo puede usarlo y de qué manera”. De este modo, el control de acceso es uno de los mecanismos de defensa fundamentales en cualquier arquitectura de seguridad de la información. Una implementación adecuada reduce la superficie de ataque de un sistema y limita el daño que puede causar tanto un actor externo malicioso como un error interno involuntario (Stallings, 2017).

En entornos GNU/Linux, el control de acceso opera a múltiples niveles: los permisos de sistema de archivos (lectura, escritura y ejecución) constituyen la capa más básica, la gestión de grupos proporciona el nivel de agrupación funcional, y herramientas como SELinux añaden capas de control obligatorio sobre las políticas discrecionales. El principio de **mínimo privilegio** (otorgar a cada sujeto solo los permisos imprescindibles para su función) es el fundamento que sustenta todos los modelos de control de acceso, y su aplicación se verificó en esta práctica (Whitman & Mattord, 2018).

Control de Acceso Discrecional (DAC)

El Control de Acceso Discrecional (*Discretionary Access Control*, DAC) es el modelo en el que el propietario de un recurso decide, de forma autónoma, qué otros sujetos pueden acceder a él y con qué permisos. Como señala Bishop (2003), “en el modelo DAC, el propietario de un objeto tiene plena discreción para conceder o revocar el acceso a ese objeto a cualquier otro sujeto del sistema”. Este modelo es el que implementan de forma nativa los sistemas Unix y GNU/Linux a través de los bits de permiso de los archivos y directorios: cada objeto del sistema de archivos posee tres conjuntos de permisos (propietario, grupo y otros) que pueden configurarse mediante el comando `chmod` con notación octal o simbólica (Garfinkel et al., 2003).

La principal ventaja del DAC es su flexibilidad: el propietario puede adaptar los permisos a sus necesidades sin intervención del administrador del sistema. Sin embargo, esta misma característica es a la vez su principal debilidad. Si el propietario concede permisos de forma inadecuada (por error o por desconocimiento) se puede producir una escalada de privilegios no prevista que un atacante puede explotar. Además, el DAC no ofrece protección frente a procesos ejecutados con las credenciales del propietario, ya que esos procesos heredan todos sus permisos (Whitman & Mattord, 2018).

Permisos en Linux: `chmod` y `chown`

En GNU/Linux, los permisos de un archivo se representan mediante nueve bits agrupados en tres tríadas: los permisos del propietario (u), del grupo (g) y del resto de usuarios (o). Cada tríada define los derechos de lectura (r), escritura (w) y ejecución (x). La notación octal condensa estos nueve bits en tres dígitos: el valor 700 indica que solo el propietario tiene permisos completos sobre el recurso, mientras que grupo y otros carecen de cualquier acceso (Garfinkel et al., 2003). El comando `chown` permite transferir la propiedad de un archivo a otro usuario o grupo, operación que en sistemas multiusuario debe reservarse al administrador para evitar apropiaciones indebidas de recursos.

Control de Acceso Basado en Roles (RBAC)

El Control de Acceso Basado en Roles (*Role-Based Access Control*, RBAC) es un modelo en el que los permisos no se asignan a cada usuario individual, sino a roles que repre-

sentan funciones organizacionales; los usuarios obtienen los permisos al ser asignados a uno o más roles. Según Hu et al. (2014), RBAC “simplifica la gestión de la seguridad al centralizar los permisos en los roles y no en los individuos, de modo que cuando un usuario cambia de función, basta con reasignar su rol en lugar de modificar uno por uno cada permiso”. Esta característica hace que RBAC resulte adecuado para organizaciones medianas y grandes, donde el número de usuarios y recursos hace inviable la gestión individual de permisos (Whitman & Mattord, 2018).

En sistemas GNU/Linux, RBAC se implementa de forma nativa mediante la gestión de grupos con los comandos `groupadd`, `usermod -aG` y la asignación de propietarios de grupo con `chown :grupo`. La combinación del permiso `770` en un directorio con la pertenencia al grupo adecuado garantiza que solo los miembros del rol correspondiente puedan acceder al recurso, mientras que los demás usuarios reciben un mensaje de *permiso denegado*. Para entornos que requieren controles granulares, Linux ofrece SELinux, que implementa un control de acceso obligatorio (MAC) superpuesto al DAC y al RBAC básicos (Hu et al., 2014).

Monitoreo de Accesos y Auditoría en Linux

El monitoreo y la auditoría de accesos constituyen la tercera dimensión del control de acceso: mientras que DAC y RBAC son controles **preventivos**, los registros de auditoría son controles **detectivos** que permiten identificar intentos de acceso no autorizado y reconstruir la secuencia de eventos tras un incidente de seguridad. Como afirman Whitman and Mattord (2018), “los registros de auditoría son esenciales para mantener la responsabilidad de los usuarios y detectar actividades sospechosas; sin un registro adecuado, es imposible determinar qué ocurrió durante un incidente de seguridad o quién fue responsable”. En sistemas GNU/Linux, el archivo `/var/log/auth.log` registra los eventos de autenticación, como los intentos de inicio de sesión exitosos y fallidos vía SSH, los cambios de usuario con `su` y las autorizaciones con `sudo` (Garfinkel et al., 2003).

La combinación de herramientas como `grep`, `cat` y `last` permite filtrar y analizar estos registros para identificar patrones de comportamiento anómalo, como múltiples intentos de acceso SSH fallidos desde una misma dirección IP (señal característica de un ataque

de fuerza bruta), o accesos en horarios inusuales. En el contexto de esta práctica, la revisión de `auth.log` tras la simulación de accesos no autorizados desde Kali Linux hacia Metasploitable 2 permitió comprobar cómo el sistema operativo registra y expone estos eventos para un análisis forense (Stallings, 2017).

Desarrollo

Fase 1: Configuración Inicial del Entorno

Antes de configurar el control de acceso, se verificó la conectividad entre los nodos del laboratorio con el comando `ping`. Esta verificación resultó necesaria para confirmar que los paquetes ICMP circulaban entre las máquinas y que la red interna estaba operativa, condición previa para la simulación de ataque por SSH de la Fase 4 (Garfinkel et al., 2003).

```
# Desde Ubuntu Desktop hacia Kali Linux
$ ping <IP_Kali> -c 4

# Desde Ubuntu Desktop hacia Metasploitable 2
$ ping <IP_Metasploitable> -c 4
```

Código 1

Verificación de conectividad entre los nodos del laboratorio mediante ping.

```
vboxuser@ubuntu:~$ ping 192.168.200.50
PING 192.168.200.50 (192.168.200.50) 56(84) bytes of data.
64 bytes from 192.168.200.50: icmp_seq=1 ttl=64 time=0.752 ms
64 bytes from 192.168.200.50: icmp_seq=2 ttl=64 time=0.469 ms
64 bytes from 192.168.200.50: icmp_seq=3 ttl=64 time=0.490 ms
^C
--- 192.168.200.50 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2567ms
rtt min/avg/max/mdev = 0.469/0.570/0.752/0.128 ms
vboxuser@ubuntu:~$ ping 192.168.200.5
PING 192.168.200.5 (192.168.200.5) 56(84) bytes of data.
64 bytes from 192.168.200.5: icmp_seq=1 ttl=64 time=0.758 ms
64 bytes from 192.168.200.5: icmp_seq=2 ttl=64 time=0.327 ms
64 bytes from 192.168.200.5: icmp_seq=3 ttl=64 time=0.382 ms
^C
--- 192.168.200.5 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2047ms
rtt min/avg/max/mdev = 0.327/0.489/0.758/0.191 ms
vboxuser@ubuntu:~$
```

Figure 2

Resultado del comando ping entre los nodos. Los paquetes ICMP se reciben sin pérdidas, lo que confirma la conectividad de la red interna.

La Figura 2 muestra la salida del `ping` con los tiempos de respuesta de cada nodo. La

ausencia de paquetes perdidos confirmó que el entorno de red quedó listo para el desarrollo del taller.

Fase 2: Control de Acceso Discrecional (DAC) en Ubuntu Desktop

Creación de Usuarios

El primer paso de la configuración DAC consistió en crear dos usuarios del sistema, `userone` y `usertwo`, con el comando `adduser`. Estos usuarios representan dos sujetos distintos sobre los que se verificaron los efectos de los permisos discrecionales aplicados al recurso (Garfinkel et al., 2003).

```
$ sudo adduser userone  
$ sudo adduser usertwo
```

Código 2

Creación de los usuarios `userone` y `usertwo` en Ubuntu Desktop.

```

vboxuser@ubuntu:~$ sudo adduser userone
info: Adding user `userone' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `userone' (1003) ...
info: Adding new user `userone' (1003) with group `userone (1003)' ...
info: Creating home directory `/home/userone' ...
info: Copying files from `/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
Sorry, passwords do not match.
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for userone
Enter the new value, or press ENTER for the default
    Full Name []: userone
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n]
info: Adding new user `userone' to supplemental / extra groups `users' ...
info: Adding user `userone' to group `users' ...

vboxuser@ubuntu:~$ sudo adduser usertwo
info: Adding user `usertwo' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `usertwo' (1004) ...
info: Adding new user `usertwo' (1004) with group `usertwo (1004)' ...
info: Creating home directory `/home/usertwo' ...
info: Copying files from `/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for usertwo
Enter the new value, or press ENTER for the default
    Full Name []: usertwo
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n]
info: Adding new user `usertwo' to supplemental / extra groups `users' ...
info: Adding user `usertwo' to group `users' ...

```

Figure 3

Creación de userone y usertwo con adduser. El sistema solicita la contraseña y los datos opcionales de cada usuario antes de confirmar la creación de su directorio personal.

Como se observa en la Figura 3, el comando `adduser` creó el directorio personal de cada usuario bajo `/home` y estableció la configuración por defecto de la cuenta.

Creación del Archivo y Asignación de Permisos

Se creó el archivo `data.txt` en el directorio personal de `userone` y se restringió su acceso exclusivamente al propietario mediante el permiso octal `700`: lectura, escritura y ejecución para `userone`, sin ningún permiso para el grupo o el resto de usuarios. Esta con-

figuración ejemplificó el principio de mínimo privilegio aplicado al modelo DAC (Whitman & Mattord, 2018).

```
# Crear el archivo como userone
$ sudo -u userone touch /home/userone/data.txt

# Aplicar permisos: solo userone puede leer, escribir y ejecutar
$ sudo chmod 700 /home/userone/data.txt

# Verificar los permisos asignados
$ ls -l /home/userone/data.txt
```

Código 3

Creación del archivo `data.txt` con permisos `700` y verificación con `ls -l`.

```
vboxuser@ubuntu:~$ sudo -u userone touch /home/userone/data.txt
vboxuser@ubuntu:~$ sudo chmod 700 /home/userone/data.txt
vboxuser@ubuntu:~$ ls -l /home/userone/
ls: cannot open directory '/home/userone/': Permission denied
vboxuser@ubuntu:~$ ls -l /home/userone/data.txt
ls: cannot access '/home/userone/data.txt': Permission denied
vboxuser@ubuntu:~$ sudo ls -l /home/userone/data.txt
-rwx----- 1 userone userone 0 Jun 25 15:23 /home/userone/data.txt
```

Figure 4

Salida de `ls -l` con los permisos `-rwx----` sobre `data.txt`. El propietario es `userone` y ningún otro usuario tiene permisos asignados sobre el archivo; un intento de lectura directa por parte de un usuario no propietario produce el mensaje `Permission denied`, y solo con `sudo` se accede al listado.

La Figura 4 confirma que los permisos se aplicaron según lo previsto. La cadena `-rwx----` indica que solo `userone` dispone de acceso completo, mientras que el grupo y el resto de usuarios no tienen ningún permiso sobre el recurso.

Verificación de Denegación de Acceso a `usertwo`

Para verificar el funcionamiento del control de acceso discrecional, se intentó leer el archivo `data.txt` como `usertwo`. Dado que este usuario no es el propietario del archivo ni pertenece a ningún grupo con permisos sobre él, el resultado esperado es la denegación del acceso, que muestra cómo el DAC protege los recursos de sujetos no autorizados (Bishop, 2003).

```
$ sudo -u usertwo cat /home/userone/data.txt
```

Código 4

Intento de acceso al archivo `data.txt` como `usertwo`, que no tiene permisos sobre él.

Como ya se evidenció en la Figura 4 (donde un usuario distinto del propietario recibe el mensaje `Permission denied` al intentar leer el archivo), el sistema rechazó el acceso. Este resultado confirmó que la política DAC aplicada impide el acceso de cualquier usuario que no sea el propietario del archivo, y validó la implementación del modelo de control de acceso discrecional en Ubuntu Desktop.

Fase 3: Control de Acceso Basado en Roles (RBAC) en Metasploitable 2

Creación de Grupos y Usuarios

En Metasploitable 2 se implementó el modelo RBAC con la creación de dos grupos que representan roles organizacionales: `admin` y `usuarios`. Después se crearon los usuarios `admin1` y `userthree` y se asignaron a sus grupos respectivos. Esta estructura replica el mecanismo RBAC, donde los permisos se definen a nivel de rol (grupo) y los usuarios heredan esos permisos al pertenecer al grupo correspondiente (Hu et al., 2014).

```
# Crear los grupos que representan los roles
$ sudo groupadd admin
$ sudo groupadd usuarios

# Crear los usuarios
$ sudo adduser admin1
$ sudo adduser userthree

# Asignar cada usuario a su rol (grupo)
$ sudo usermod -aG admin admin1
$ sudo usermod -aG usuarios userthree
```

Código 5

Creación de grupos, usuarios y asignación de membresía de grupo en Metasploitable 2.


```

vboxuser@ubuntu:~$ sudo groupadd admin
vboxuser@ubuntu:~$ sudo groupadd usuarios
vboxuser@ubuntu:~$ sudo adduser admin1
info: Adding user `admin1' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `admin1' (1007) ...
info: Adding new user `admin1' (1007) with group `admin1 (1007)' ...
info: Creating home directory `/home/admin1' ...
info: Copying files from `/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for admin1
Enter the new value, or press ENTER for the default
    Full Name []: admin1
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n]
info: Adding new user `admin1' to supplemental / extra groups `users' ...
info: Adding user `admin1' to group `users' ...
vboxuser@ubuntu:~$ sudo adduser userthree
info: Adding user `userthree' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `userthree' (1008) ...
info: Adding new user `userthree' (1008) with group `userthree (1008)' ...
info: Creating home directory `/home/userthree' ...
info: Copying files from `/etc/skel' ...
New password:
BAD PASSWORD: The password contains the user name in some form

vboxuser@ubuntu:~$ sudo usermod -aG admin admin1
vboxuser@ubuntu:~$ sudo usermod -aG usuarios user3
usermod: user 'user3' does not exist
vboxuser@ubuntu:~$ sudo usermod -aG usuarios userthree
vboxuser@ubuntu:~$

```

Figure 5

Creación de los grupos admin y usuarios, creación de los usuarios admin1 y userthree, y asignación de cada usuario a su grupo correspondiente con usermod -aG.

La Figura 5 confirma la ejecución correcta de los comandos de configuración RBAC. El flag -aG de usermod agrega el usuario al grupo indicado sin eliminar su pertenencia a otros grupos, condición necesaria para preservar el acceso a los recursos del sistema base.

Creación del Directorio Protegido por Rol

Se creó el directorio /admin-dir y se configuró para que únicamente los miembros del grupo admin puedan acceder a él. El permiso 770 garantiza acceso completo al propietario y al grupo, mientras que todos los demás usuarios carecen de cualquier permiso sobre el directorio (Garfinkel et al., 2003).

```

# Crear el directorio protegido
$ sudo mkdir /admin-dir

# Asignar el grupo admin como propietario del directorio

```

```
$ sudo chown :admin /admin-dir

# Permiso 770: admin r/w/x | admin(grupo) r/w/x | otros: nada
$ sudo chmod 770 /admin-dir

# Verificar permisos
$ ls -ld /admin-dir
```

Código 6

Creación del directorio /admin-dir, asignación de propietario de grupo y configuración de permisos 770.

```
vboxuser@ubuntu:~$ sudo chown :admin /admin-dir/
vboxuser@ubuntu:~$ sudo chmod 770 /admin-dir/

vboxuser@ubuntu:~$ sudo ls -ld /admin-dir
drwxrwx--- 2 root admin 4096 Jun 25 15:34 /admin-dir
```

Figure 6

Salida de `ls -ld /admin-dir` con los permisos `drwxrwx--` y propietario de grupo `admin`. Solo los miembros del grupo `admin` tienen acceso al directorio.

La Figura 6 muestra la cadena de permisos `drwxrwx--`, que confirma que el grupo `admin` tiene acceso completo al directorio y que otros (incluyendo `userthree`) no disponen de ningún permiso sobre él.

Verificación de Denegación de Acceso a `userthree`

Se intentó acceder al directorio protegido como `userthree`, quien pertenece al grupo `usuarios` y no al grupo `admin`. El resultado esperado es un mensaje de *permiso denegado*, que confirma que el modelo RBAC implementado impide el acceso a recursos fuera del alcance del rol del usuario (Whitman & Mattord, 2018).

```
$ sudo -u userthree ls /admin-dir
```

Código 7

Intento de acceso al directorio /admin-dir como `userthree`, que no pertenece al grupo `admin`.

```
vboxuser@ubuntu:~$ sudo -u userthree ls /admin-dir
ls: cannot open directory '/admin-dir': Permission denied
```

Figure 7

Mensaje Permission denied producido al intentar acceder a /admin-dir como userthree. El sistema aplica correctamente la política RBAC: solo los miembros del grupo admin pueden acceder al directorio protegido.

Como se verifica en la Figura 7, el sistema rechazó el intento de acceso de userthree. A continuación se comprobó que admin1, como miembro del grupo admin, sí accede al directorio /admin-dir. Esta segunda prueba completó la validación bidireccional del modelo RBAC.

```
$ sudo -u admin1 ls /admin-dir
```

Código 8

Verificación del acceso correcto de admin1 al directorio protegido como miembro del grupo admin.

El acceso autorizado de admin1 a este mismo directorio se evidencia más adelante, en la simulación remota por SSH de la Fase 4 (Figura 9). La comparación entre el acceso denegado a userthree (Figura 7) y el acceso concedido a admin1 demuestra que el modelo RBAC implementado funciona según lo esperado: el mismo recurso resulta accesible para el rol autorizado e inaccesible para un rol sin permisos, tal como define el principio de control de acceso basado en roles (Hu et al., 2014).

Fase 4: Simulación de Ataque desde Kali Linux

Esta fase simuló el comportamiento de un atacante que intentó acceder a recursos protegidos en Metasploitable 2 por SSH. La simulación permitió observar cómo los controles de acceso configurados en las fases anteriores resisten los intentos de acceso no autorizado desde una máquina externa, y cómo esos intentos quedan registrados en los logs del sistema (Stallings, 2017).

```
# Intentar conexion SSH como userthree desde Kali Linux
$ ssh userthree@<IP_Metasploitable2>

# Una vez conectado, intentar acceder al directorio protegido
```

```
$ ls /admin-dir
```

Código 9

Simulación de ataque desde Kali Linux: conexión SSH como userthree e intento de acceso al directorio protegido.

```
(effy@kali)-[~]
$ ssh userthree@192.168.200.4
The authenticity of host '192.168.200.4 (192.168.200.4)' can't be established.
ED25519 key fingerprint is: SHA256:4xZVxBzPOaGVLh5JA6S6978tymWCJIC6ZrQ7qzH3DH4
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.200.4' (ED25519) to the list of known hosts.
userthree@192.168.200.4's password:
Permission denied, please try again.
userthree@192.168.200.4's password:
Permission denied, please try again.
userthree@192.168.200.4's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-35-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

80 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

9 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

userthree@ubuntu:~$ ls /admin-dir/
ls: cannot open directory '/admin-dir/': Permission denied
```

Figure 8

Conexión SSH desde Kali Linux como userthree hacia Metasploitable 2. La sesión SSH se establece, pero el intento de listar /admin-dir es denegado por el sistema con el mensaje Permission denied.

```
# Conexion SSH como admin1
$ ssh admin1@<IP_Metasploitable2>

# Verificar acceso al directorio protegido
$ ls /admin-dir
```

Código 10

Verificación del acceso correcto desde Kali Linux como admin1, que sí pertenece al grupo admin.

```

(effy@kali)-[~]
└─$ ssh admin1@192.168.200.4
admin1@192.168.200.4's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-35-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

80 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

9 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin1@ubuntu:~$ ls /admin-dir/
admin1@ubuntu:~$

```

Figure 9

Conexión SSH desde Kali Linux como admin1 y acceso exitoso al directorio /admin-dir. El rol admin mantiene sus privilegios incluso en sesiones remotas, lo que valida la robustez del modelo RBAC implementado.

Las Figuras 8 y 9 demuestran que los controles de acceso basados en roles configurados en Metasploitable 2 fueron efectivos tanto en sesiones locales como en sesiones SSH remotas. El sistema distinguió entre usuarios autorizados y no autorizados sin importar el vector de acceso empleado.

Fase 5: Monitoreo y Auditoría en Metasploitable 2

El análisis de los registros del sistema tras la fase de ataque simulado permitió identificar los eventos de acceso SSH que registró el demonio de autenticación del sistema operativo. El archivo `/var/log/auth.log` es la fuente primaria de evidencia de auditoría en sistemas Debian/Ubuntu y sus derivados, y `last` ofrece un historial cronológico de las últimas sesiones de usuario (Garfinkel et al., 2003).

```

# Filtrar eventos SSH en el log de autenticacion
$ sudo cat /var/log/auth.log | grep "ssh"

# Ver las ultimas conexiones al sistema
$ last

```

Código 11

Revisión de los registros de acceso SSH en `auth.log` y verificación de las últimas sesiones con `last`.

```
vboxuser@ubuntu:~$ sudo cat /var/log/auth.log | grep "ssh"
vboxuser@ubuntu:~$ last
```

admin1	pts/3	192.168.200.50	Thu Jun 25 16:01	still logged in
userthree	pts/3	192.168.200.50	Thu Jun 25 16:00 - 16:01	(00:00)
vboxuser	tty2		Tue Jun 23 15:32	gone - no logout
vboxuser	seat0	login screen	Tue Jun 23 15:32	gone - no logout
reboot	system boot	6.17.0-35-generi	Tue Jun 23 15:32	still running
vboxuser	tty2		Tue Jun 23 15:29 - crash	(00:02)
vboxuser	seat0	login screen	Tue Jun 23 15:29 - crash	(00:02)

Figure 10

Revisión de `/var/log/auth.log` filtrada con `grep "ssh"` y salida del comando `last`. En el historial de sesiones se identifican las conexiones de `userthree` y `admin1` desde la IP de Kali Linux (192.168.200.50), con sus respectivas marcas de tiempo y duración de sesión.

Como se aprecia en la Figura 10, que reúne tanto el filtrado de `auth.log` como el historial cronológico devuelto por `last`, el sistema registró todas las conexiones SSH producidas durante el taller. Esto confirmó que, aun sin una herramienta de monitoreo adicional, GNU/Linux ofrece un mecanismo de auditoría nativo suficiente para detectar y documentar accesos no autorizados, en línea con lo que señalan Whitman and Mattord (2018) sobre la importancia de los controles detectivos en cualquier política de seguridad.

Actividad Extra: Diseño e Implementación de un Escenario de Control de Acceso

Descripción del Escenario

Como escenario de aplicación se seleccionó una **empresa de telecomunicaciones** dedicada a la prestación de servicios de telefonía móvil, telefonía fija, internet por fibra óptica y televisión por suscripción. Esta organización administra la información de miles de clientes y se estructura en varios departamentos (Soporte Técnico, Operaciones, Atención al Cliente y Administración de Infraestructura), cada uno con necesidades de acceso diferenciadas sobre los recursos del sistema (Whitman & Mattord, 2018).

La información crítica que la empresa debe proteger comprende la base de datos de clientes y su información personal (nombres, direcciones, teléfonos y correos electrónicos), los contratos y la información de facturación, las configuraciones de los equipos de red, las

credenciales de acceso a los servidores y la documentación técnica interna. Un acceso no autorizado a estos recursos expondría a la organización a riesgos de alto impacto, entre los que destacan el robo de información personal de los clientes, la modificación o eliminación de configuraciones críticas, la interrupción de los servicios de telecomunicaciones, las pérdidas económicas, el incumplimiento de las normativas de protección de datos y el consiguiente daño a la reputación de la empresa (Stallings, 2017).

Definición de Usuarios y Roles

Para aplicar el principio de mínimo privilegio se definieron cuatro usuarios distribuidos en dos roles organizacionales. El **Administrador** dispone de acceso a todas las funcionalidades del sistema, mientras que el **Analista** puede realizar consultas sobre determinados datos de ciertas tablas, sin capacidad para modificarlos ni para revisar la información sensible. La Tabla 2 resume la clasificación de los usuarios según su rol (Hu et al., 2014).

Table 2

Clasificación de los usuarios de la empresa de telecomunicaciones según su rol.

Usuario	Rol	Grupo asignado
admintelecom	Administrador	administradores
supervisor	Administrador	administradores
analista1	Analista	analistas
invitado	Invitado	— (cuenta sin privilegios)

Aplicación de los Modelos de Control de Acceso

Creación de Usuarios

El primer paso consistió en crear las cuatro cuentas de usuario con el comando `useradd -m` (que genera el directorio personal de cada cuenta) y en asignar una contraseña a cada una con `passwd` (Garfinkel et al., 2003).

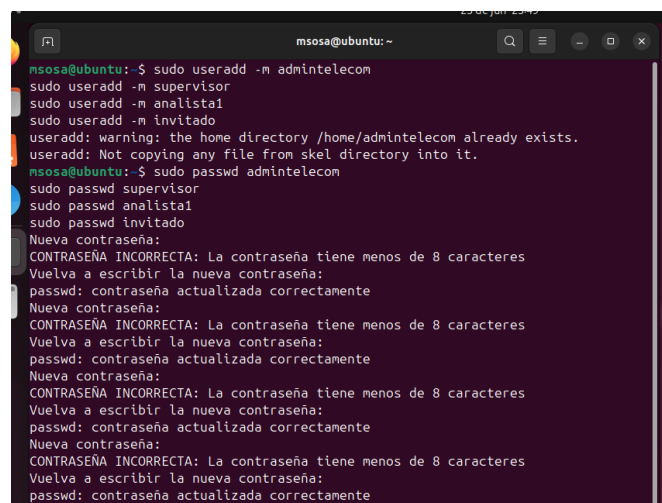
```
$ sudo useradd -m admintelecom
$ sudo useradd -m supervisor
$ sudo useradd -m analista1
$ sudo useradd -m invitado
```



```
$ sudo passwd admintelecom
$ sudo passwd supervisor
$ sudo passwd analista1
$ sudo passwd invitado
```

Código 12

Creación de los cuatro usuarios de la empresa de telecomunicaciones y asignación de sus contraseñas.



```
msosa@ubuntu:~$ sudo useradd -m admintelecom
sudo useradd -m supervisor
sudo useradd -m analista1
sudo useradd -m invitado
useradd: warning: the home directory /home/admintelecom already exists.
useradd: Not copying any file from skel directory into it.
msosa@ubuntu:~$ sudo passwd admintelecom
sudo passwd supervisor
sudo passwd analista1
sudo passwd invitado
Nueva contraseña:
CONTRASEÑA INCORRECTA: La contraseña tiene menos de 8 caracteres
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
Nueva contraseña:
CONTRASEÑA INCORRECTA: La contraseña tiene menos de 8 caracteres
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
Nueva contraseña:
CONTRASEÑA INCORRECTA: La contraseña tiene menos de 8 caracteres
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
Nueva contraseña:
CONTRASEÑA INCORRECTA: La contraseña tiene menos de 8 caracteres
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
```

Figure 11

Creación de los usuarios admintelecom, supervisor, analista1 e invitado con useradd -m y asignación de sus respectivas contraseñas mediante passwd.

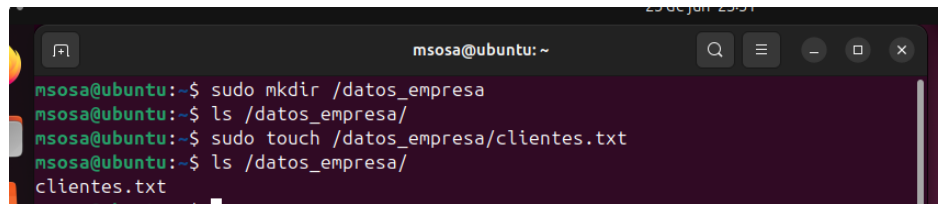
Creación del Directorio y del Archivo Confidencial

A continuación se creó el directorio `/datos_empresa`, destinado a almacenar la información sensible de la organización, y dentro de él el archivo `clientes.txt`, que representa la base de datos de clientes (Whitman & Mattord, 2018).

```
$ sudo mkdir /datos_empresa
$ sudo touch /datos_empresa/clientes.txt
```

Código 13

Creación del directorio `/datos_empresa` y del archivo confidencial `clientes.txt`.



```
msosa@ubuntu:~$ sudo mkdir /datos_empresa
msosa@ubuntu:~$ ls /datos_empresa/
msosa@ubuntu:~$ sudo touch /datos_empresa/clientes.txt
msosa@ubuntu:~$ ls /datos_empresa/
clientes.txt
```

Figure 12

Creación del directorio /datos_empresa y del archivo clientes.txt en su interior, verificada con ls.

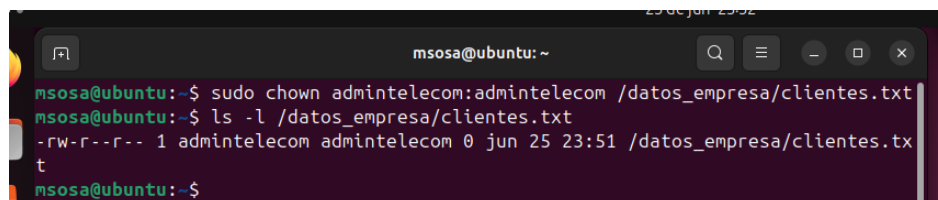
Asignación de Propietario

Se asignó al usuario admintelecom como propietario del archivo clientes.txt mediante chown, de modo que el control discrecional sobre el recurso recayera exclusivamente en la cuenta administradora (Garfinkel et al., 2003).

```
$ sudo chown admintelecom:admintelecom /datos_empresa/clientes.txt
$ ls -l /datos_empresa/clientes.txt
```

Código 14

Asignación de admintelecom como propietario del archivo clientes.txt.



```
msosa@ubuntu:~$ sudo chown admintelecom:admintelecom /datos_empresa/clientes.txt
msosa@ubuntu:~$ ls -l /datos_empresa/clientes.txt
-rw-r--r-- 1 admintelecom admintelecom 0 jun 25 23:51 /datos_empresa/clientes.txt
msosa@ubuntu:~$
```

Figure 13

Asignación de admintelecom como propietario (usuario y grupo) del archivo confidencial clientes.txt con chown.

Configuración de Permisos (DAC)

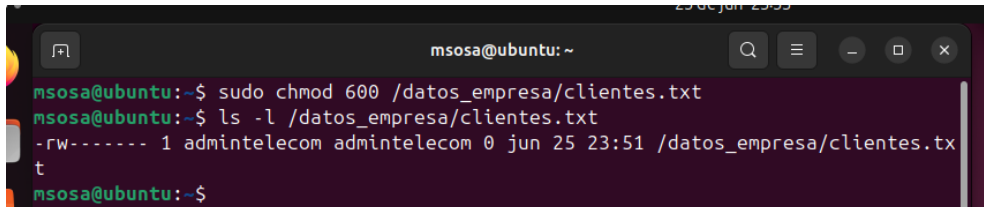
Sobre el archivo confidencial se aplicó el modelo DAC con el permiso octal 600: lectura y escritura exclusivas para el propietario, sin ningún permiso para el grupo ni para el resto de usuarios. Esta configuración materializa el principio de mínimo privilegio sobre el recurso más sensible de la organización (Bishop, 2003).

```
# Solo el propietario podra leer y escribir el archivo
$ sudo chmod 600 /datos_empresa/clientes.txt
```

```
# Verificar los permisos asignados
$ ls -l /datos_empresa/clientes.txt
```

Código 15

Aplicación del permiso 600 sobre clientes.txt y verificación con ls -l.



```
msosa@ubuntu:~$ sudo chmod 600 /datos_empresa/clientes.txt
msosa@ubuntu:~$ ls -l /datos_empresa/clientes.txt
-rw----- 1 admintelecom admintelecom 0 jun 25 23:51 /datos_empresa/clientes.tx
t
msosa@ubuntu:~$
```

Figure 14

Salida de ls -l con la cadena de permisos -rw----- sobre clientes.txt. Únicamente admintelecom puede leer y modificar el archivo.

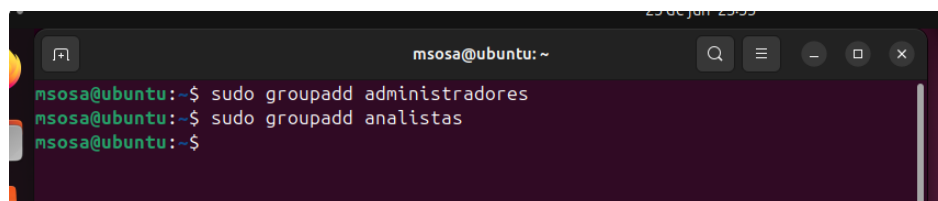
Creación de Grupos (RBAC)

Para implementar el modelo RBAC se crearon dos grupos que representan los roles organizacionales descritos en la Tabla 2: administradores y analistas (Hu et al., 2014).

```
$ sudo groupadd administradores
$ sudo groupadd analistas
```

Código 16

Creación de los grupos administradores y analistas que representan los roles de la organización.



```
msosa@ubuntu:~$ sudo groupadd administradores
msosa@ubuntu:~$ sudo groupadd analistas
msosa@ubuntu:~$
```

Figure 15

Creación de los grupos administradores y analistas con groupadd, según los roles definidos en la Tabla 2.

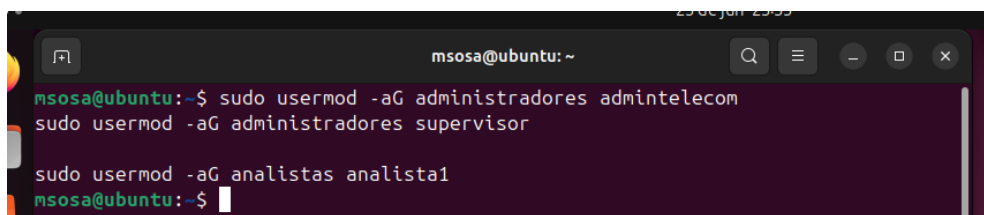
Asignación de Usuarios a los Grupos

Finalmente, cada usuario se asignó a su rol con `usermod -aG`. Los usuarios `admintelecom` y `supervisor` se incorporaron al grupo `administradores`, mientras que `analista1` se asignó al grupo `analistas`. El flag `-aG` agrega al usuario al grupo indicado sin eliminar sus pertenencias previas (Garfinkel et al., 2003).

```
$ sudo usermod -aG administradores admintelecom
$ sudo usermod -aG administradores supervisor
$ sudo usermod -aG analistas analista1
```

Código 17

Asignación de cada usuario a su grupo (rol) correspondiente con `usermod -aG`.



```
msosa@ubuntu: ~
msosa@ubuntu:~$ sudo usermod -aG administradores admintelecom
msosa@ubuntu:~$ sudo usermod -aG administradores supervisor
msosa@ubuntu:~$ sudo usermod -aG analistas analista1
msosa@ubuntu:~$
```

Figure 16

Asignación de `admintelecom` y `supervisor` al grupo `administradores`, y de `analista1` al grupo `analistas`, con `usermod -aG`.

Pruebas de Funcionamiento

Acceso de un Usuario Autorizado

Para validar la configuración se inició sesión como `admintelecom` (el propietario del archivo) con `su` y se accedió al contenido de `clientes.txt`. Al disponer de los permisos de lectura, el sistema mostró la información sin restricciones (Bishop, 2003).

```
$ su - admintelecom
$ cd /datos_empresa
$ ls -l
$ cat clientes.txt
```

Código 18

Acceso autorizado al archivo confidencial como `admintelecom`, propietario del recurso.

```
msosa@ubuntu:~$ su - admintelecom
Contraseña:
$ cd /datos_empresa
$ ls -l
total 4
-rw----- 1 admintelecom admintelecom 32 jun 26 00:04 clientes.txt
$ cat clientes.txt
Datos importantes de la empresa
$
```

Figure 17

Acceso autorizado de admintelecom al archivo clientes.txt. El usuario propietario lee el contenido del archivo sin restricciones.

Acceso de un Usuario sin Permisos

A continuación se inició sesión como `analista1`, que no es propietario del archivo ni pertenece a un grupo con permisos sobre él. Al intentar leer `clientes.txt`, el sistema operativo denegó el acceso, lo que confirma la eficacia de la política DAC configurada (Whitman & Mattord, 2018).

```
$ su - analista1
$ cd /datos_empresa
$ ls
$ cat clientes.txt
```

Código 19

Intento de acceso al archivo confidencial como analista1, usuario sin permisos sobre el recurso.

```
msosa@ubuntu:~$ su - analista1
Contraseña:
$ cd /datos_empresa
$ ls
clientes.txt
$ cat clientes.txt
cat: clientes.txt: Permiso denegado
$
```

Figure 18

Mensaje Permiso denegado al intentar leer clientes.txt como analista1. El permiso 600 impide el acceso a cualquier usuario distinto del propietario.

Tabla Resumen de Permisos

La Tabla 3 resume la política de control de acceso implementada en el escenario de la empresa de telecomunicaciones, con los recursos a los que cada usuario puede o no acceder.

Table 3

Resumen de permisos asignados en el escenario de la empresa de telecomunicaciones.

Usuario	Rol	Recursos permitidos	Recursos denegados
admintelecom	Administrador	Lectura y escritura de <code>clientes.txt</code> (propietario)	Ninguno
supervisor	Administrador	Recursos del grupo <code>administradores</code>	<code>clientes.txt</code> (no es el propietario)
analista1	Analista	Consultas autorizadas del grupo <code>analistas</code>	<code>clientes.txt</code>
invitado	Invitado	Recursos públicos del sistema	<code>/datos_empresa</code> y <code>clientes.txt</code>

Análisis

¿Qué ventajas ofrece DAC en este escenario?

En el escenario de la empresa de telecomunicaciones, el modelo DAC permite que el propietario del recurso (en este caso `admintelecom`) controle de forma directa y autónoma quién puede acceder al archivo de la base de datos de clientes. Su principal ventaja es la sencillez de implementación y la granularidad a nivel de archivo individual, que resulta idónea para proteger recursos específicos de alta sensibilidad, como `clientes.txt`, sin necesidad de modificar políticas centralizadas (Bishop, 2003).

¿Qué ventajas ofrece RBAC?

RBAC simplifica la administración de los permisos al asociarlos a roles (grupos) en lugar de configurarlos usuario por usuario. En una empresa de telecomunicaciones con numerosos empleados distribuidos en distintos departamentos, basta con agregar un nuevo trabajador al grupo `administradores` o `analistas` para que herede los permisos del rol, lo que facilita el mantenimiento, reduce los errores de configuración y mejora la escalabilidad de

la política de seguridad (Hu et al., 2014).

¿Qué modelo se recomendaría implementar en una organización real y por qué?

Se recomienda implementar principalmente **RBAC**, ya que una empresa de telecomunicaciones cuenta con un gran número de empleados con responsabilidades diferenciadas. La administración mediante roles facilita la incorporación de nuevos usuarios, reduce los errores en la asignación de permisos y fortalece la seguridad (Whitman & Mattord, 2018). El modelo DAC puede emplearse de forma complementaria para proteger archivos específicos que requieran permisos personalizados, como `clientes.txt`; y para entornos que exijan controles más estrictos, ambos modelos pueden reforzarse con SELinux, que añade una capa de control de acceso obligatorio (MAC) independiente del propietario del recurso.

¿Qué vulnerabilidades podrían existir si los permisos estuvieran mal configurados?

Una configuración incorrecta de los permisos introduciría varios vectores de ataque. Si el archivo `clientes.txt` tuviera permisos `644`, cualquier usuario del sistema (incluido `invitado`) podría leer la información personal de los clientes, lo que constituiría un robo de datos y un incumplimiento de las normativas de protección de datos. Si el directorio `/datos_empresa` tuviera permisos `777`, cualquier usuario podría modificar o eliminar configuraciones críticas, con el consiguiente riesgo de escalada de privilegios, interrupción de los servicios de telecomunicaciones y daño a la reputación de la empresa. La ausencia de una política de mínimo privilegio amplificaría, además, el impacto de cualquier proceso comprometido que se ejecutara con las credenciales de un usuario legítimo (Stallings, 2017).

Conclusiones

La práctica demostró de forma experimental que la combinación de DAC y RBAC en entornos GNU/Linux ofrece una estrategia de control de acceso complementaria y eficaz. El DAC permitió proteger archivos individuales de alta sensibilidad con granularidad a nivel de propietario, mientras que el RBAC facilitó la gestión estructurada del acceso a directorios compartidos mediante grupos que representan roles organizacionales. En ambos casos, el sistema operativo impuso las restricciones previstas y emitió mensajes de `Permission denied` ante los intentos de acceso no autorizado, tanto en sesiones locales como en sesiones SSH remotas desde Kali Linux (Whitman & Mattord, 2018).

El análisis de los registros de auditoría en `/var/log/auth.log` evidenció que GNU/Linux registra los eventos de autenticación SSH, lo que ofrece una capacidad de monitoreo y trazabilidad sin necesidad de herramientas adicionales. Esto confirmó la importancia de los controles detectivos como complemento de los controles preventivos (DAC y RBAC), ya que permiten identificar amenazas después de que ocurren y orientar mejoras en la política de seguridad (Stallings, 2017). Por último, la actividad extra de diseño del escenario de empresa de telecomunicaciones demostró que la definición adecuada de usuarios, roles y permisos, basada en el principio de mínimo privilegio, constituye la base de cualquier política de control de acceso robusta y auditable (Hu et al., 2014).

Recomendaciones

A partir de los resultados obtenidos, se plantean las siguientes recomendaciones para fortalecer la política de control de acceso y replicar la práctica en condiciones más cercanas a un entorno productivo:

- **Aplicar el principio de mínimo privilegio.** Asignar a cada usuario y rol solo los permisos imprescindibles para su función y evitar configuraciones abiertas como `777` o `644` sobre recursos sensibles, tal como mostró el análisis de vulnerabilidades de la actividad extra (Whitman & Mattord, 2018).
- **Privilegiar RBAC sobre la asignación individual de permisos.** En organizaciones con varios usuarios, gestionar el acceso mediante grupos que representen roles reduce los errores de configuración y simplifica las altas, bajas y rotaciones de personal, sin necesidad de modificar cada recurso de forma individual (Hu et al., 2014).
- **Complementar DAC y RBAC con control de acceso obligatorio (MAC).** Para recursos de alta sensibilidad, habilitar y configurar SELinux en modo *enforcing* añade una capa de control independiente del propietario del archivo y mitiga los riesgos inherentes a la discrecionalidad del DAC (Bishop, 2003).
- **Establecer una política de auditoría y monitoreo continuo.** Revisar con regularidad `/var/log/auth.log` y centralizar los registros en un servidor dedicado permite

detectar patrones de ataque (como intentos reiterados de acceso SSH fallidos) antes de que se materialice un incidente (Stallings, 2017).

- **Reforzar el acceso remoto SSH.** Sustituir la autenticación por contraseña por autenticación basada en pares de claves, deshabilitar el acceso directo del usuario `root` y restringir las direcciones de origen reduce la superficie de ataque expuesta en la simulación realizada desde Kali Linux (Garfinkel et al., 2003).
- **Documentar y versionar la matriz de permisos.** Mantener actualizada la tabla de usuarios, roles y recursos (como la elaborada en la actividad extra) facilita las auditorías de seguridad y la trazabilidad de los cambios en la política de control de acceso.

Referencias

- Bishop, M. (2003). *Computer security: Art and science*. Addison-Wesley. <https://www.pearson.com/en-us/subject-catalog/p/computer-security-art-and-science/P200000003346>
- Garfinkel, S., Spafford, G., & Schwartz, A. (2003). *Practical UNIX and internet security* (3rd ed.). O'Reilly Media. <https://www.oreilly.com/library/view/practical-unix-and/0596003234/>
- Hu, V. C., Ferraiolo, D., Kuhn, R., Schnitzer, A., Sandlin, K., Miller, R., & Scarfone, K. (2014). *Guide to attribute based access control (ABAC) definition and considerations* (Special Publication No. NIST SP 800-162). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-162>
- Stallings, W. (2017). *Cryptography and network security: Principles and practice* (7th ed.). Pearson Education. <https://www.pearson.com/en-us/subject-catalog/p/cryptography-and-network-security-principles-and-practice/P200000003477>
- Whitman, M. E., & Mattord, H. J. (2018). *Principles of information security* (6th ed.). Cengage Learning. <https://www.cengage.com/c/principles-of-information-security-6e-whitman-mattord/9781337102063/>



Taller 2: Comparación entre el NIST Cybersecurity Framework (CSF 2.0) y la ISO/IEC 27002:2022

Marcos David Escobar Vela

Stefany Maricela Díaz Antun

Diego Mateo Sosa Flores

Universidad de las Fuerzas Armadas ESPE

Carrera de Software

Ingeniería Seguridad del Software

Julio 2026

Contents

Glosario de Términos	4
1 Resumen	5
2 Objetivos de aprendizaje	6
3 Topología de prueba	6
4 Marco Teórico	7
4.1 Marcos de Gestión de Ciberseguridad	7
4.2 NIST Cybersecurity Framework 2.0	8
4.2.1 Estructura del NIST CSF 2.0	8
4.2.2 La función Govern como innovación central	8
4.3 ISO/IEC 27002:2022	9
4.3.1 Sistema de Gestión de Seguridad de la Información (SGSI)	9
4.4 Tipos de Controles de Seguridad	10
4.5 Integración de los Marcos y Gestión de Riesgos	10
5 Desarrollo	11
5.1 Caracterización de los Marcos	11
5.1.1 Caracterización del NIST CSF 2.0	11
5.1.2 Caracterización de la ISO/IEC 27002:2022	13
5.2 Tipos de Controles	15
5.3 Matriz Comparativa	17
5.4 Caso Práctico	19
5.4.1 Perímetro: Firewall con política de denegación por defecto	20
5.4.2 Acceso remoto cifrado: VPN	22
5.4.3 Gestión de identidades: Active Directory	24
5.4.4 Protección de datos: Base de Datos	27
5.4.5 Codificación segura: Servidor Web	28

5.4.6	Monitoreo continuo del acceso remoto	30
5.4.7	Respaldo y recuperación	32
5.5	Análisis Crítico	33
6	Conclusiones	34
6.1	¿Cuál marco está más orientado hacia la gestión?	35
6.2	¿Cuál posee mayor detalle en controles?	35
6.3	¿Cuál es más sencillo para comenzar un programa de ciberseguridad?	35
6.4	¿Cuál facilita una certificación?	35
6.5	¿Cuál se considera más apropiado para una institución pública ecuatoriana?	35
6.6	¿Cuál sería más apropiado para una PyME?	36
6.7	¿Cómo podrían integrarse ambos marcos dentro de un SGSI?	36
6.8	¿Cuál marco ofrece mayor flexibilidad?	36
6.9	¿Cuál proporciona mayor profundidad en controles?	36
6.10	¿En qué casos conviene utilizar ambos?	37
6.11	¿Qué aprendió el grupo durante el análisis?	37
6.12	¿Qué marco se recomendaría implementar en la organización propuesta?	37
7	Recomendaciones	37

List of Figures

1	Topología del escenario empresarial de referencia: Firewall, Servidor Web, VPN, Active Directory, Base de Datos y LAN corporativa con usuarios remotos.	7
2	Estructura del CSF Core del NIST Cybersecurity Framework 2.0 con sus seis funciones: Govern, Identify, Protect, Detect, Respond y Recover.	13
3	Distribución de los 93 controles de la ISO/IEC 27002:2022 en sus cuatro temas: Organizativo, Personas, Físico y Tecnológico.	15
4	Mapeo entre los tipos de control de ISO/IEC 27002:2022 (preventivo, detectivo, correctivo) y las seis funciones del NIST CSF 2.0.	17
5	Evidencia de ejecución del control A.8.20: reglas de firewall con <code>nftables</code> y verificación de la política <code>drop</code> por defecto sobre la VM.	22

6	Evidencia de ejecución del control A.8.21: generación de las claves Wire-Guard y configuración del túnel cifrado <code>wg0</code> en la VM.	24
7	Evidencia de ejecución del control A.5.15: corrección de la resolución de nombres (<code>/etc/hosts</code>) e inicio del aprovisionamiento del dominio <code>ANDESTECH.LOCAL</code>	25
8	Evidencia de ejecución del control A.5.15: política de contraseñas del dominio aplicada y verificada con <code>samba-tool domain passwordsettings show</code>	26
9	Evidencia de ejecución del control A.8.12: activación de TLS en PostgreSQL y verificación de la conexión cifrada (<code>SSL connection (protocol: TLSv1.3...)</code>).	28
10	Evidencia de ejecución del control A.8.28: creación de la tabla <code>clientes</code> , inserción de un registro de prueba e implementación de la consulta parametrizada en <code>app/consultas.py</code>	30
11	Evidencia de ejecución del control A.6.7: simulación de un ataque de fuerza bruta (seis intentos SSH fallidos) y consulta del estado de la jaula <code>sshd</code> de <code>fail2ban</code>	31
12	Esquema del procedimiento de detección y bloqueo del control A.6.7: los intentos fallidos de SSH quedan en <code>auth.log</code> , <code>fail2ban</code> los correlaciona y, al superar el umbral, bloquea la dirección de origen.	32
13	Esquema del procedimiento del control correctivo A.8.13: la base de datos se respalda cifrada, y ante un incidente se restaura en un entorno de prueba donde se verifica la integridad del dato recuperado.	33

List of Tables

2	Caracterización del NIST Cybersecurity Framework 2.0.	12
3	Caracterización de la ISO/IEC 27002:2022.	14
4	Tipos de controles según ISO/IEC 27002:2022.	16
5	Matriz comparativa entre NIST CSF 2.0 e ISO/IEC 27002:2022.	17
6	Aplicación de controles de ambos marcos al escenario de AndesTech S.A. . . .	20

Glosario de Términos

Acrónimo	Definición
AD	<i>Active Directory</i> . Servicio de directorio de Microsoft que centraliza la autenticación, la autorización y las políticas de los usuarios y equipos de una red corporativa.
CIA	<i>Confidentiality, Integrity, Availability</i> (Confidencialidad, Integridad, Disponibilidad). Tríada de propiedades de seguridad que la ISO/IEC 27002:2022 asigna como atributo a cada control.
CIS	<i>Center for Internet Security</i> . Organización que publica los controles CIS, catálogo priorizado de buenas prácticas con el que ambos marcos disponen de mapeos.
COBIT	<i>Control Objectives for Information and Related Technologies</i> . Marco de gobernanza de tecnologías de la información publicado por ISACA, empleado en estudios comparativos de marcos de ciberseguridad.
CSF	<i>Cybersecurity Framework</i> . Marco de ciberseguridad del NIST; en este taller se analiza su versión 2.0, publicada en 2024.
IDS/IPS	<i>Intrusion Detection System / Intrusion Prevention System</i> . Sistemas de detección y prevención de intrusiones que actúan como controles detectivos en el escenario analizado.
ISO/IEC	<i>International Organization for Standardization / International Electrotechnical Commission</i> . Organismos internacionales que publican de forma conjunta la familia de normas 27000.
LAN	<i>Local Area Network</i> (Red de Área Local). Red interna corporativa que interconecta los servidores y las estaciones de trabajo del escenario empresarial.
NIST	<i>National Institute of Standards and Technology</i> . Instituto estadounidense que publica el CSF 2.0 y el catálogo de controles SP 800-53.
PCI DSS	<i>Payment Card Industry Data Security Standard</i> . Estándar de seguridad para datos de tarjetas de pago, citado en la literatura comparativa de marcos.
PHVA	Planificar-Hacer-Verificar-Actuar (<i>Plan-Do-Check-Act</i> , PDCA). Ciclo de mejora continua sobre el que se estructura un SGSI.
PyME	Pequeña y Mediana Empresa. Tipo de organización considerado en el análisis de aplicabilidad de los marcos.
SGSI	Sistema de Gestión de Seguridad de la Información (<i>ISMS</i>). Sistema de gestión definido por ISO/IEC 27001 para administrar los riesgos de seguridad de la información.
VPN	<i>Virtual Private Network</i> (Red Privada Virtual). Canal cifrado que permite el acceso remoto seguro de los usuarios externos a la LAN corporativa.

Resumen

Este taller desarrolló un análisis comparativo entre el NIST Cybersecurity Framework (CSF) 2.0 y la norma ISO/IEC 27002:2022, dos de los marcos de referencia con mayor adopción para la gestión de la seguridad de la información. En primer lugar se caracterizó cada marco según su objetivo, alcance, estructura, funciones, ventajas, limitaciones y proceso de certificación, con base en la documentación oficial del NIST y de la ISO. Después se identificaron los tipos de controles (preventivos, detectivos y correctivos) y su correspondencia con las seis funciones del CSF 2.0. La comparación se formalizó en una matriz de veinte parámetros que abarcó aspectos de estructura, prescripción, certificabilidad, costo y aplicabilidad. Los marcos se aplicaron luego a un caso práctico sobre un escenario empresarial compuesto por un Firewall, un Servidor Web, una VPN, Active Directory, una Base de Datos y una LAN corporativa con usuarios remotos. El análisis crítico concluyó que ambos marcos son complementarios: el CSF 2.0 aporta la capa de gobernanza y comunicación del riesgo, mientras que la ISO/IEC 27002:2022 ofrece la profundidad técnica de sus 93 controles dentro de un SGSI certificable vía ISO/IEC 27001.

Palabras clave: NIST CSF 2.0, ISO/IEC 27002:2022, controles de seguridad, SGSI, gobernanza, gestión de riesgos, ciberseguridad.

Objetivos de aprendizaje

- El estudiante aprendió a caracterizar el NIST Cybersecurity Framework 2.0 y la ISO/IEC 27002:2022 a partir de su estructura, alcance, funciones y tipos de controles, y estableció las diferencias fundamentales entre un marco orientado a resultados y una norma prescriptiva de controles de seguridad de la información.
- Se aprendió a construir una matriz comparativa de veinte parámetros entre ambos marcos, con el análisis de aspectos como la certificabilidad, la cobertura de controles, la aplicabilidad por sector y el nivel de prescripción, para fundamentar decisiones técnicas sobre la adopción de marcos de ciberseguridad en escenarios organizacionales reales.
- Con el desarrollo de este taller se fortaleció la capacidad de análisis crítico para determinar la integración complementaria del NIST CSF 2.0 y la ISO/IEC 27002:2022 dentro de un Sistema de Gestión de Seguridad de la Información (SGSI). Dicho análisis se aplicó a un escenario empresarial con Firewall, VPN, Active Directory y bases de datos corporativas.

Topología de prueba

Para el desarrollo de este taller se empleó como referencia un escenario empresarial típico compuesto por un **Firewall** perimetral que separa la red interna de Internet, un **Servidor Web** publicado hacia el exterior, una **VPN** para el acceso cifrado de los usuarios remotos, un servidor de **Active Directory** para la gestión centralizada de identidades, una **Base de Datos** corporativa y una **LAN** con estaciones de trabajo. A diferencia de los talleres anteriores, esta práctica fue de análisis documental, por lo que la topología no se implementó sobre máquinas virtuales, sino que sirvió como escenario de aplicación de los controles de ambos marcos en el caso práctico.

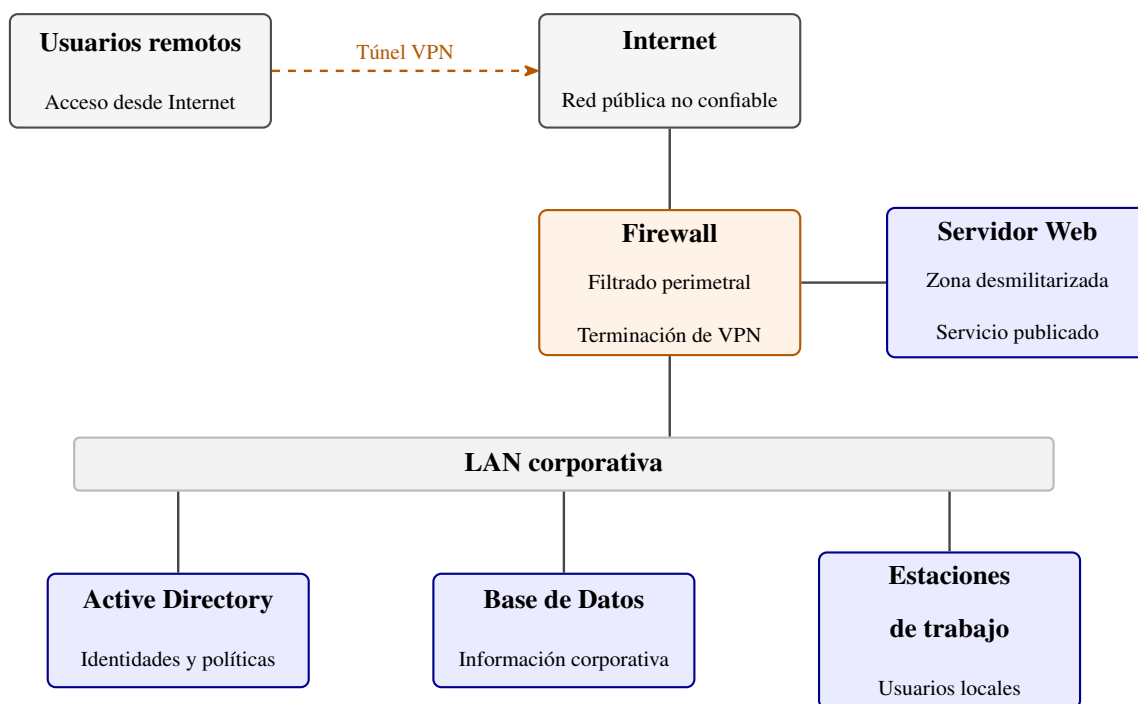


Figure 1

Topología del escenario empresarial de referencia: Firewall, Servidor Web, VPN, Active Directory, Base de Datos y LAN corporativa con usuarios remotos.

Como se aprecia en la Figura 1, el Firewall concentra el tráfico entre la red pública y la LAN corporativa, la VPN provee el canal cifrado para los usuarios remotos y los servicios críticos (Active Directory y Base de Datos) residen en la red interna. Sobre estos componentes se aplicaron los controles de ambos marcos en la sección del caso práctico.

Marco Teórico

Marcos de Gestión de Ciberseguridad

Los marcos de gestión de ciberseguridad son conjuntos estructurados de directrices, controles y buenas prácticas que permiten a las organizaciones identificar, evaluar y gestionar sus riesgos de seguridad de la información de forma sistemática y reproducible. A diferencia de las soluciones técnicas puntuales, estos marcos adoptan una visión integral que abarca personas, procesos y tecnología, y ofrecen un lenguaje común para comunicar la postura de seguridad entre equipos técnicos, directivos y reguladores (Pascoe et al., 2024). Su adopción creció de forma sostenida: el número de certificaciones ISO 27001 válidas a nivel mundial se duplicó entre 2023 y 2024, hasta alcanzar los 96.709 certificados según la encuesta de certificaciones ISO, mientras que las menciones al NIST CSF en informes anuales de empre-

sas públicas estadounidenses se multiplicaron por 22 en el mismo período (Risk Publishing, 2026).

NIST Cybersecurity Framework 2.0

El NIST Cybersecurity Framework (CSF) 2.0 fue publicado el 26 de febrero de 2024 por el Instituto Nacional de Estándares y Tecnología de los Estados Unidos (NIST) como una taxonomía voluntaria de resultados de ciberseguridad aplicable a cualquier organización, independientemente de su tamaño, sector o nivel de madurez (Pascoe et al., 2024). El propio documento establece que *“the CSF does not prescribe how outcomes should be achieved. Rather, it links to online resources that provide additional guidance on practices and controls that could be used to achieve those outcomes”*, lo que subraya su carácter orientado a resultados en lugar de prescriptivo. La versión 2.0 amplió el alcance original (diseñado en 2014 solo para infraestructuras críticas) a toda clase de organizaciones, e introdujo la función *Govern* como sexto pilar estructural. Con esta incorporación, la gobernanza alcanzó un nivel de prioridad equivalente a la respuesta técnica ante incidentes. Entre los recursos vinculados al CSF destaca el catálogo de controles NIST SP 800-53, que traduce los resultados del marco en salvaguardas concretas de seguridad y privacidad (Joint Task Force Interagency Working Group, 2020).

Estructura del NIST CSF 2.0

El CSF 2.0 se organiza en torno a tres componentes interdependientes. El **CSF Core** es la taxonomía central de resultados de ciberseguridad, estructurada en seis *Functions* (Govern, Identify, Protect, Detect, Respond y Recover), cada una subdividida en Categorías y Subcategorías que totalizan 106 resultados específicos. Los **Tiers de implementación** (Parcial, Informado por riesgos, Repetible y Adaptativo) permiten a las organizaciones autoevaluar la madurez con que gestionan sus riesgos cibernéticos. Los **Perfiles organizacionales** (perfil actual y perfil objetivo) constituyen el mecanismo operativo para identificar brechas y priorizar inversiones (Pascoe et al., 2024).

La función Govern como innovación central

La función Govern es la aportación central del CSF 2.0 respecto a su versión anterior. Según NIST, esta función aborda cómo *“an organization’s cybersecurity risk management*

strategy, expectations, and policy are established, communicated, and monitored”, y cubre aspectos como el contexto organizacional, la estrategia de ciberseguridad, la gestión de riesgos en la cadena de suministro, los roles y responsabilidades, y la supervisión ejecutiva (Pascoe et al., 2024). Esta incorporación aproxima el CSF 2.0 a la estructura de gobernanza propia de los estándares ISO y cierra una brecha que los críticos de la versión 1.1 habían señalado durante años. La literatura reciente refuerza la pertinencia de esta función: la revisión sistemática de Modi et al. (2023) evidencia la necesidad de métricas de riesgo cibernético comprensibles para los consejos directivos, ámbito que la función Govern atiende de forma directa.

ISO/IEC 27002:2022

La norma ISO/IEC 27002:2022, publicada en febrero de 2022, constituye la guía de implementación de los controles de seguridad de la información que conforman el Anexo A de la norma ISO/IEC 27001:2022 (ISO/IEC, 2022b). Su función dentro de la familia de estándares ISO/IEC 27000 es ofrecer orientación detallada sobre *cómo* implementar cada control, en complemento de los *requisitos* que establece ISO 27001 (ISO/IEC, 2022a). La revisión de 2022 representó la reestructuración más profunda desde 2013: los 114 controles organizados en 14 dominios se consolidaron en 93 controles agrupados en cuatro temas (Organizativo, Personas, Físico y Tecnológico) y se incorporaron 11 controles nuevos relacionados con inteligencia de amenazas, servicios en la nube, prevención de fuga de datos y codificación segura (ISO Library, 2024).

La norma también introdujo cinco atributos para cada control (tipo [preventivo, detective, correctivo], propiedades de seguridad [CIA], conceptos de ciberseguridad alineados al NIST CSF, capacidades operativas y dominios de seguridad) que facilitan el filtrado, la asignación de responsabilidades y la integración con otros marcos (ISO Library, 2024). A diferencia del NIST CSF, ISO 27002 no es directamente certificable; la certificación formal se obtiene mediante ISO 27001, cuyo Anexo A incorpora los 93 controles de ISO 27002 como referencia normativa.

Sistema de Gestión de Seguridad de la Información (SGSI)

El SGSI es el marco de gestión sobre el que se apoya ISO 27001 y al que ISO 27002 aporta los controles técnicos. Un SGSI, según la norma, es el sistema mediante el cual una or-

ganización gestiona los riesgos relacionados con la confidencialidad, integridad y disponibilidad de su información, con el ciclo Planificar-Hacer-Verificar-Actuar (PHVA) como mecanismo de mejora continua (ISO/IEC, 2022a). Su implementación permite a las organizaciones no solo seleccionar controles técnicos apropiados, sino también demostrar frente a clientes, socios y reguladores que la seguridad se gestiona de forma sistemática y verificable (Anonymous, 2026).

Tipos de Controles de Seguridad

La ISO/IEC 27002:2022 clasifica los controles según su naturaleza en tres tipos: **preventivos** (reducen la probabilidad de que ocurra un incidente), **detectivos** (identifican amenazas o anomalías cuando ocurren) y **correctivos** (mitigan el impacto una vez que el incidente se ha materializado). Esta clasificación tripartita se complementa con los atributos de dominio (gobernanza, protección, defensa y resiliencia) que permiten agrupar controles según la estrategia de seguridad predominante (ISO Library, 2024). El NIST CSF 2.0, por su parte, no prescribe tipos de controles de forma explícita, sino que organiza los resultados esperados en sus seis funciones; sin embargo, sus Subcategorías pueden mapearse con los controles ISO 27002 gracias a los atributos de concepto de ciberseguridad incorporados en la norma, que utilizan las cinco funciones del CSF original (Identify, Protect, Detect, Respond, Recover) como referencia de alineación (Pascoe et al., 2024).

Integración de los Marcos y Gestión de Riesgos

La adopción conjunta del NIST CSF 2.0 y la ISO/IEC 27002:2022 dentro de un SGSI no solo es posible sino que genera sinergias documentadas en la literatura especializada. El CSF 2.0 proporciona el modelo de gobernanza y la estructura orientada a resultados para comunicar la postura de seguridad a nivel ejecutivo, mientras que ISO 27002 aporta la profundidad técnica de sus 93 controles para traducir esos resultados en acciones operativas concretas (Ebers et al., 2024). Como señala el estudio comparativo de Sulistyowati, Handayani, et al. (2021), los marcos de ciberseguridad difieren en cobertura, énfasis y nivel de abstracción, lo que convierte su integración complementaria en una estrategia más robusta que la adopción de cualquiera de ellos por separado. En la práctica, las organizaciones que buscan certificación internacional adoptan ISO 27001/27002 como estructura formal del SGSI

y utilizan el CSF 2.0 como herramienta de comunicación y *benchmarking* frente a reguladores y consejos directivos. La selección de combinaciones adecuadas de controles a partir de catálogos estandarizados constituye, además, un problema de decisión activo en la investigación reciente, lo que confirma que la adopción de un marco no es un ejercicio mecánico sino una decisión de ingeniería (Léveillé & Jaskolka, 2025).

Desarrollo

Caracterización de los Marcos

En esta sección se caracterizan de forma individual ambos marcos según su objetivo, alcance, estructura, funciones, ventajas, limitaciones y proceso de certificación, con base en la documentación oficial del NIST y de la Organización Internacional de Normalización (ISO).

Caracterización del NIST CSF 2.0

El NIST Cybersecurity Framework 2.0 tiene como objetivo proporcionar una taxonomía de resultados de ciberseguridad de alto nivel aplicable a cualquier organización. La Tabla 2 resume sus características principales.

Table 2*Caracterización del NIST Cybersecurity Framework 2.0.*

Aspecto	Descripción
Objetivo	Gestionar y reducir riesgos de ciberseguridad mediante resultados esperados.
Alcance	Universal: cualquier organización, sector, tamaño o nivel de madurez.
Estructura	CSF Core (Funciones, Categorías, Subcategorías), Tiers y Perfiles.
Funciones	Seis: Govern, Identify, Protect, Detect, Respond, Recover.
Naturaleza	Marco orientado a resultados, voluntario y no prescriptivo.
Ventajas	Gratuito, flexible, de rápida adopción; lenguaje común con la alta dirección; Perfiles para el análisis de brechas.
Limitaciones	No es certificable; carece de guía técnica de implementación, por lo que requiere catálogos complementarios como SP 800-53.
Certificación	No certificable de forma directa; es una guía de referencia.
Organismo	National Institute of Standards and Technology (NIST), EE.UU.
Publicación	CSWP 29, 26 de febrero de 2024.
Sitio oficial	https://www.nist.gov/cyberframework

La Figura 2 muestra la estructura del CSF Core con sus seis funciones organizadas de forma cíclica, lo que evidencia la posición central de la función Govern.



Figure 2

Estructura del CSF Core del NIST Cybersecurity Framework 2.0 con sus seis funciones: Govern, Identify, Protect, Detect, Respond y Recover.

Caracterización de la ISO/IEC 27002:2022

La ISO/IEC 27002:2022 tiene como objetivo proporcionar orientación detallada sobre la implementación de los controles de seguridad de la información. La Tabla 3 resume sus características.

Table 3*Caracterización de la ISO/IEC 27002:2022.*

Aspecto	Descripción
Objetivo	Guiar la implementación de controles de seguridad de la información.
Alcance	Organizaciones que implementan un SGSI basado en ISO 27001.
Estructura	93 controles agrupados en 4 temas y 5 atributos por control.
Temas	Organizativo (37), Personas (8), Físico (14), Tecnológico (34).
Naturaleza	Guía de implementación de controles, detallada y prescriptiva.
Ventajas	Controles con propósito y guía de implementación; atributos que facilitan el mapeo con otros marcos; ruta hacia la certificación internacional.
Limitaciones	Norma de pago; menor flexibilidad; exige un SGSI formal y auditorías externas para certificar vía ISO 27001.
Certificación	No certificable por sí sola; la certificación es vía ISO 27001.
Organismo	International Organization for Standardization (ISO/IEC).
Publicación	Febrero de 2022 (tercera edición).
Sitio oficial	https://www.iso.org/standard/75652.html

La Figura 3 muestra la distribución de los 93 controles de ISO/IEC 27002:2022 según los cuatro temas de la norma.



Figure 3

Distribución de los 93 controles de la ISO/IEC 27002:2022 en sus cuatro temas: Organizativo, Personas, Físico y Tecnológico.

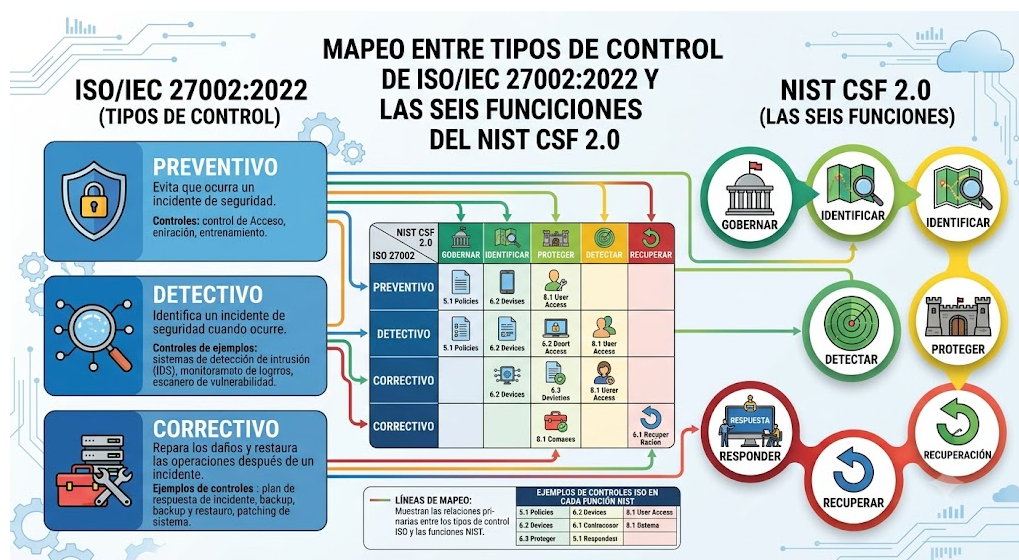
Tipos de Controles

La ISO/IEC 27002:2022 clasifica sus controles según el tipo en tres categorías fundamentales, que se resumen en la Tabla 4. Esta clasificación es relevante porque permite equilibrar la estrategia de seguridad entre la anticipación de amenazas, su detección y la mitigación de sus efectos.

Table 4*Tipos de controles según ISO/IEC 27002:2022.*

Tipo	Función	<i>Ejemplo en el escenario</i>
Preventivo	Reduce la probabilidad de que ocurra un incidente antes de que suceda.	<i>Firewall, VPN, políticas de contraseñas en Active Directory.</i>
Detectivo	Identifica amenazas o anomalías en el momento en que ocurren.	<i>Logs de acceso, IDS/IPS, monitoreo de la base de datos.</i>
Correctivo	Mitiga el impacto una vez que el incidente se ha materializado.	<i>Respallos, plan de recuperación, restauración de servicios.</i>

En el marco del NIST CSF 2.0, los controles no se clasifican por tipo de forma explícita, sino que se agrupan por la función a la que contribuyen. La Figura 4 ilustra cómo los tipos de control de ISO 27002 se corresponden con las funciones del CSF 2.0, lo que evidencia la complementariedad entre ambos marcos.

**Figure 4**

Mapeo entre los tipos de control de ISO/IEC 27002:2022 (preventivo, detectivo, correctivo) y las seis funciones del NIST CSF 2.0.

Matriz Comparativa

La Tabla 5 presenta la comparación entre el NIST CSF 2.0 y la ISO/IEC 27002:2022 a través de veinte parámetros diferenciados, que cubren aspectos de estructura, alcance, aplicabilidad y proceso de certificación.

Table 5

Matriz comparativa entre NIST CSF 2.0 e ISO/IEC 27002:2022.

Parámetro	NIST CSF 2.0	ISO/IEC 27002:2022
1. Organismo emisor	NIST (Estados Unidos)	ISO/IEC (internacional)
2. Año de publicación	2024 (versión 2.0)	2022 (tercera edición)
3. Naturaleza	Marco orientado a resultados	Guía de controles
4. Enfoque	Gestión de riesgos	Implementación de controles
5. Nivel de prescripción	Bajo (qué lograr)	Alto (cómo implementar)

continúa en la siguiente página

Table 5 – *continuación*

Parámetro	NIST CSF 2.0	ISO/IEC 27002:2022
6. Estructura principal	6 funciones	4 temas
7. Número de elementos	106 subcategorías	93 controles
8. Certificable	No directamente	Vía ISO 27001
9. Costo de acceso	Gratuito	De pago (norma ISO)
10. Alcance geográfico	Global, origen EE.UU.	Global
11. Función de gobernanza	Explícita (Govern)	Distribuida en temas
12. Cadena de suministro	Categoría dedicada (GV.SC)	Controles específicos
13. Flexibilidad	Alta	Media
14. Profundidad de control	Media	Alta
15. Curva de aprendizaje	Baja	Media-alta
16. Uso en sector público	Frecuente (EE.UU.)	Frecuente (global)
17. Modelo de madurez	Tiers (1 a 4)	No incluye tiers
18. Perfiles	Actual y objetivo	No aplica
19. Actualización	Cada varios años	Cada varios años
20. Integración con otros	Alta (mapea a 800-53, ISO)	Alta (mapea a CSF, CIS)

Caso Práctico

El caso práctico aplicó ambos marcos a un escenario empresarial concreto y lo materializó mediante una implementación simulada de controles sobre cada activo. Al no disponer de una guía cerrada, el grupo propuso como organización de referencia a *AndesTech S.A.*, una empresa mediana ecuatoriana del sector de servicios tecnológicos (alrededor de 120 empleados, con personal en teletrabajo), cuya red corresponde a la topología de la Figura 1: un Firewall perimetral, un Servidor Web publicado, una VPN de acceso remoto, un servidor de Active Directory, una Base de Datos corporativa y una LAN con estaciones de trabajo. Para cada activo se seleccionó un control representativo de ISO/IEC 27002:2022 y su resultado equivalente en el NIST CSF 2.0, junto con el tipo de control (preventivo, detectivo o correctivo) definido en la Tabla 4. La Tabla 6 resume ese mapeo, y los apartados siguientes muestran, para cada componente, el comando o fragmento de código que implementa el control y su verificación.

Table 6

Aplicación de controles de ambos marcos al escenario de AndesTech S.A.

Componente	Tipo	NIST CSF 2.0 (función)	ISO/IEC 27002 (control)
Firewall	Preventivo	PR.IR — Protección de infraestructura	A.8.20 Seguridad de redes
VPN	Preventivo	PR.AA — Autenticación y control de acceso	A.8.21 Seguridad de servicios de red
Active Directory	Preventivo	PR.AA — Gestión de identidades	A.5.15 Control de acceso
Base de Datos	Preventivo	PR.DS — Seguridad de datos	A.8.12 Prevención de fuga de datos
Servidor Web	Preventivo	PR.PS — Seguridad de plataformas	A.8.28 Codificación segura
Usuarios remotos	Detectivo	DE.CM — Monitoreo continuo	A.6.7 Trabajo remoto
Respaldo y recuperación	Correctivo	RC.RP — Recuperación de servicios	A.8.13 Respaldo de la información

Perímetro: Firewall con política de denegación por defecto

Como control *preventivo* de red (A.8.20 / PR.IR), el firewall aplicó una política `drop` por defecto y solo abrió los puertos estrictamente necesarios: HTTPS del servidor web publicado, el puerto de la VPN y SSH restringido a la subred de administración (192.168.100.0/24). El Código 1 muestra las reglas con `nftables` y su verificación, cuya evidencia de ejecución se presenta en la Figura 5.

```
# firewall-perimetral: politica por defecto "denegar" y apertura minima
sudo nft add table inet filtro
```

```

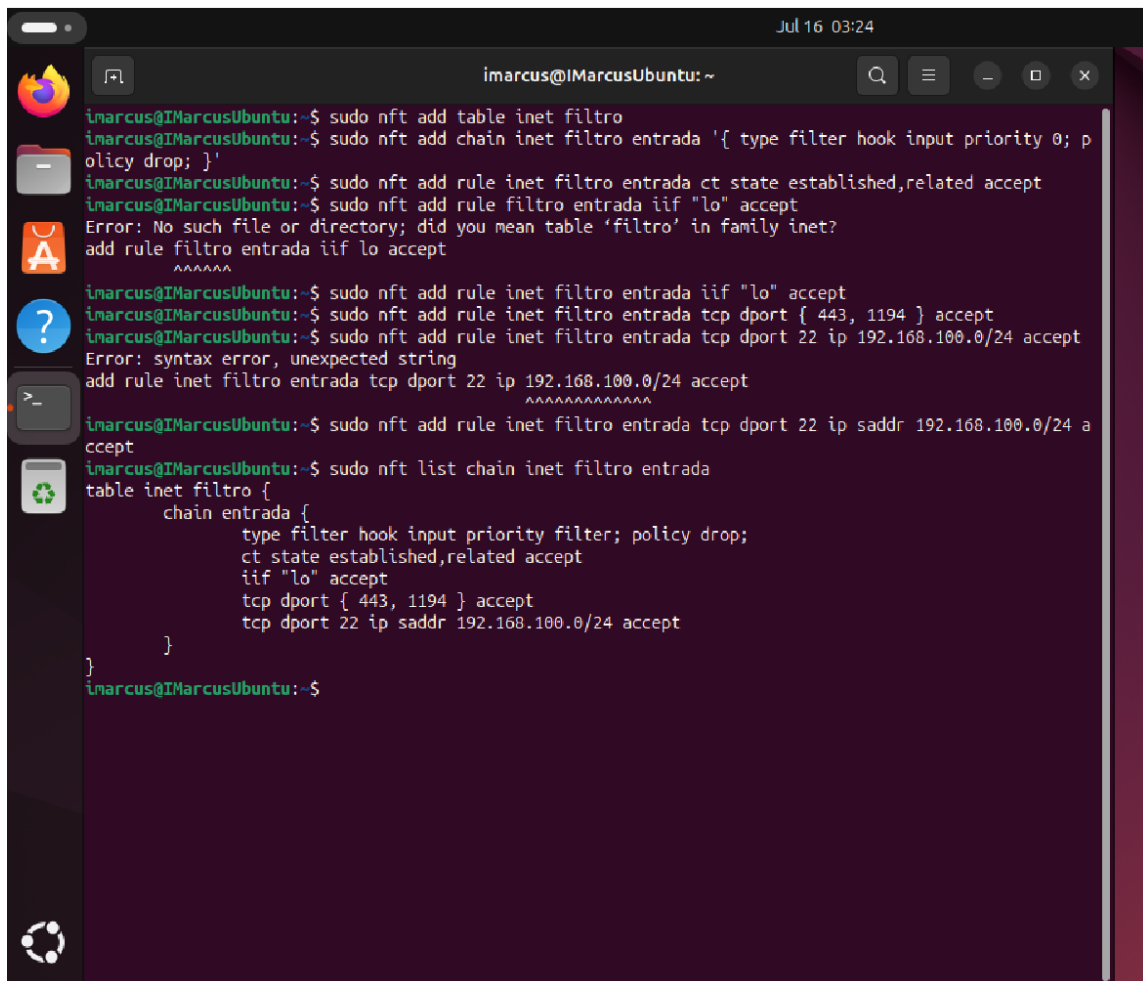
sudo nft add chain inet filtro entrada '{ type filter hook input
    priority 0; policy drop; }'
sudo nft add rule inet filtro entrada ct state established,related
    accept
sudo nft add rule inet filtro entrada iif "lo" accept
sudo nft add rule inet filtro entrada tcp dport { 443, 1194 } accept    #
    HTTPS publicado y VPN
sudo nft add rule inet filtro entrada tcp dport 22 ip saddr
    192.168.100.0/24 accept    # SSH solo LAN de administracion

# Verificacion de la politica activa
sudo nft list chain inet filtro entrada
table inet filtro {
    chain entrada {
        type filter hook input priority filter; policy drop;
        ct state established,related accept
        iif "lo" accept
        tcp dport { 443, 1194 } accept
        tcp dport 22 ip saddr 192.168.100.0/24 accept
    }
}

```

Código 1

Reglas de firewall perimetral con nftables (control A.8.20).



```

imarcus@IMarcusUbuntu: ~
imarcus@IMarcusUbuntu:~$ sudo nft add table inet filtro
imarcus@IMarcusUbuntu:~$ sudo nft add chain inet filtro entrada '{ type filter hook input priority 0; policy drop; }'
imarcus@IMarcusUbuntu:~$ sudo nft add rule inet filtro entrada ct state established,related accept
imarcus@IMarcusUbuntu:~$ sudo nft add rule filtro entrada iif "lo" accept
Error: No such file or directory; did you mean table 'filtro' in family inet?
add rule filtro entrada iif lo accept
imarcus@IMarcusUbuntu:~$ sudo nft add rule inet filtro entrada iif "lo" accept
imarcus@IMarcusUbuntu:~$ sudo nft add rule inet filtro entrada tcp dport { 443, 1194 } accept
imarcus@IMarcusUbuntu:~$ sudo nft add rule inet filtro entrada tcp dport 22 ip 192.168.100.0/24 accept
Error: syntax error, unexpected string
add rule inet filtro entrada tcp dport 22 ip 192.168.100.0/24 accept
imarcus@IMarcusUbuntu:~$ sudo nft add rule inet filtro entrada tcp dport 22 ip saddr 192.168.100.0/24 accept
imarcus@IMarcusUbuntu:~$ sudo nft list chain inet filtro entrada
table inet filtro {
    chain entrada {
        type filter hook input priority filter; policy drop;
        ct state established,related accept
        iif "lo" accept
        tcp dport { 443, 1194 } accept
        tcp dport 22 ip saddr 192.168.100.0/24 accept
    }
}
imarcus@IMarcusUbuntu:~$

```

Figure 5

Evidencia de ejecución del control A.8.20: reglas de firewall con *nftables* y verificación de la política drop por defecto sobre la VM.

Acceso remoto cifrado: VPN

Para el teletrabajo se configuró una VPN WireGuard terminada en el firewall (A.8.21 / PR.AA), que protege la *confidencialidad* del tráfico remoto. Se generó el par de claves criptográficas del servidor y se definió al usuario remoto autorizado como *peer*. El Código 2 presenta la generación de claves y la configuración del túnel, con la evidencia de ejecución en la Figura 6.

```

# Generar el par de claves del servidor
wg genkey | sudo tee /etc/wireguard/privatekey | wg pubkey | sudo tee /
etc/wireguard/publickey
oD/oxGyluFJbypiAeOeYFeY/VWDZfpyROuM5hmebXmE=

```



```

# Generar la clave publica del usuario remoto autorizado (peer)
wg genkey | wg pubkey
fodK9hoSJCOrgCwCAZn+9gCxLQ+YLwG9cVmlap98Pyg=

# /etc/wireguard/wg0.conf -- terminacion de la VPN en el firewall
[Interface]
Address      = 10.8.0.1/24
ListenPort   = 1194
PrivateKey   = oD/oxGyluFJbypiAeOeYFeY/VWDZfpyROuM5hmebXmE=

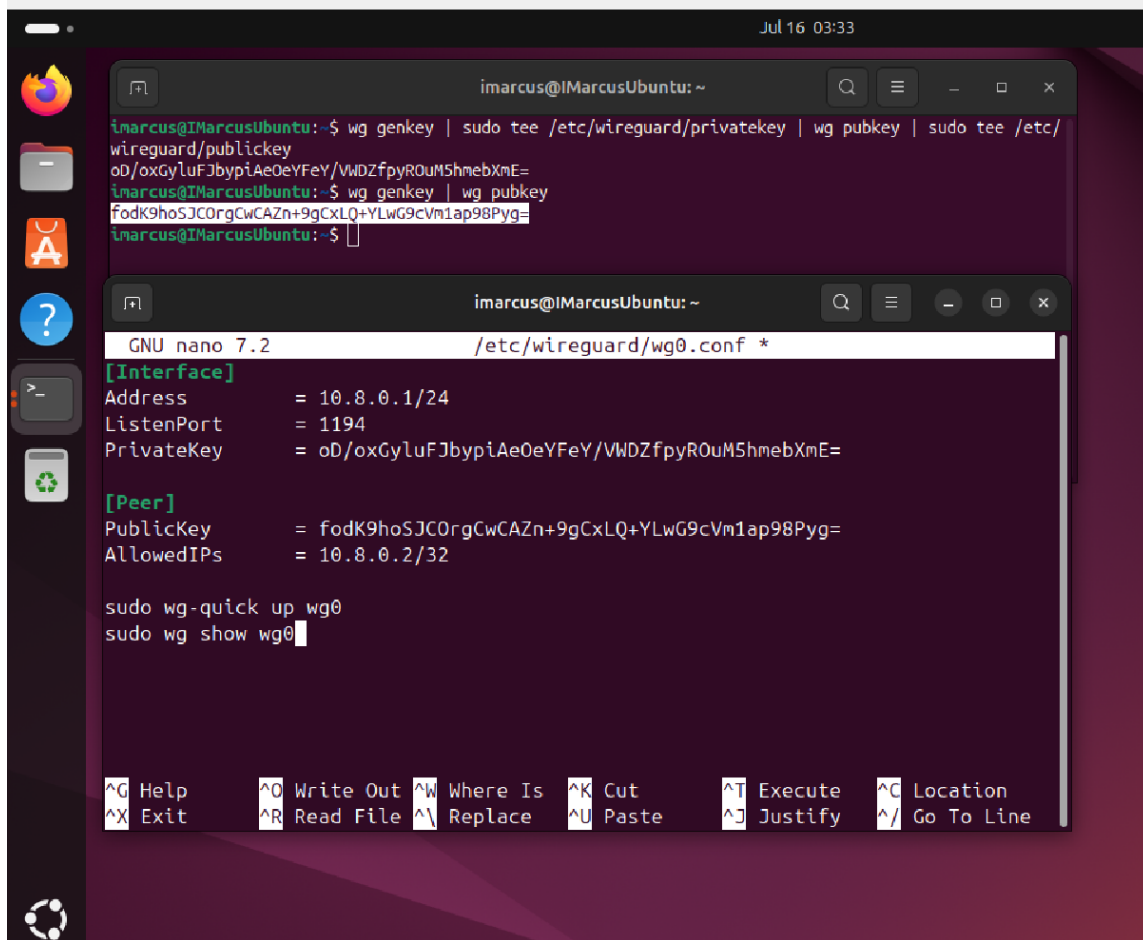
[Peer]
# laptop de un usuario remoto autorizado
PublicKey    = fodK9hoSJCOrgCwCAZn+9gCxLQ+YLwG9cVmlap98Pyg=
AllowedIPs   = 10.8.0.2/32

# Levantar el tunel cifrado
sudo wg-quick up wg0

```

Código 2

Configuración del túnel VPN WireGuard (control A.8.21).



```

imarcus@IMarcusUbuntu: ~
imarcus@IMarcusUbuntu:~$ wg genkey | sudo tee /etc/wireguard/privatekey | wg pubkey | sudo tee /etc/
wireguard/publickey
oD/oxGyluFJbypIAeOeYFeY/VWDZfpyROuM5hnebXmE=
imarcus@IMarcusUbuntu:~$ wg genkey | wg pubkey
fodK9hoSJC0rgCwCAZn+9gCxLQ+YLwG9cVm1ap98Pyg=
imarcus@IMarcusUbuntu:~$

GNU nano 7.2 /etc/wireguard/wg0.conf *
[Interface]
Address          = 10.8.0.1/24
ListenPort      = 1194
PrivateKey       = oD/oxGyluFJbypIAeOeYFeY/VWDZfpyROuM5hnebXmE=

[Peer]
PublicKey        = fodK9hoSJC0rgCwCAZn+9gCxLQ+YLwG9cVm1ap98Pyg=
AllowedIPs       = 10.8.0.2/32

sudo wg-quick up wg0
sudo wg show wg0

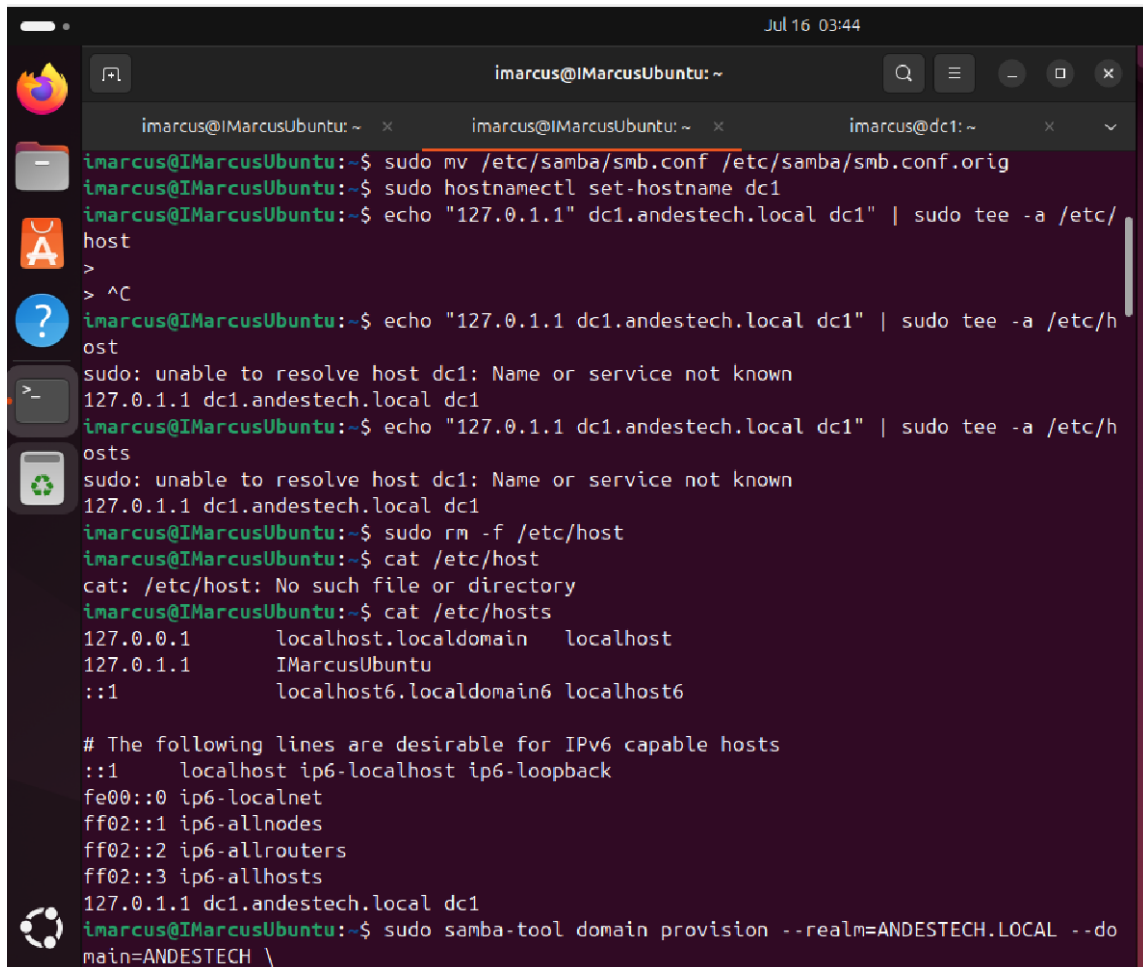
```

Figure 6

Evidencia de ejecución del control A.8.21: generación de las claves WireGuard y configuración del túnel cifrado wg0 en la VM.

Gestión de identidades: Active Directory

Se promovió el servidor a controlador de dominio Active Directory con `samba-tool` (dominio `ANDESTECH.LOCAL`) y, sobre él, se endureció la política de contraseñas (A.5.15 / PR.AA) como control preventivo de acceso, con exigencia de complejidad, longitud mínima de 12 caracteres, historial y caducidad. La Figura 7 evidencia el aprovisionamiento del dominio, y el Código 3 muestra el ajuste de la política y su verificación, cuya ejecución se presenta en la Figura 8.



```

imarcus@IMarcusUbuntu: ~
imarcus@IMarcusUbuntu:~$ sudo mv /etc/samba/smb.conf /etc/samba/smb.conf.orig
imarcus@IMarcusUbuntu:~$ sudo hostnamectl set-hostname dc1
imarcus@IMarcusUbuntu:~$ echo "127.0.1.1 dc1.andestech.local dc1" | sudo tee -a /etc/
host
>
> ^C
imarcus@IMarcusUbuntu:~$ echo "127.0.1.1 dc1.andestech.local dc1" | sudo tee -a /etc/h
ost
sudo: unable to resolve host dc1: Name or service not known
127.0.1.1 dc1.andestech.local dc1
imarcus@IMarcusUbuntu:~$ echo "127.0.1.1 dc1.andestech.local dc1" | sudo tee -a /etc/h
osts
sudo: unable to resolve host dc1: Name or service not known
127.0.1.1 dc1.andestech.local dc1
imarcus@IMarcusUbuntu:~$ sudo rm -f /etc/host
imarcus@IMarcusUbuntu:~$ cat /etc/host
cat: /etc/host: No such file or directory
imarcus@IMarcusUbuntu:~$ cat /etc/hosts
127.0.0.1        localhost.localdomain localhost
127.0.1.1        IMarcusUbuntu
::1              localhost6.localdomain6 localhost6

# The following lines are desirable for IPv6 capable hosts
::1      localhost ip6-localhost ip6-loopback
fe00::0  ip6-localnet
ff02::1  ip6-allnodes
ff02::2  ip6-allrouters
ff02::3  ip6-allhosts
127.0.1.1 dc1.andestech.local dc1
imarcus@IMarcusUbuntu:~$ sudo samba-tool domain provision --realm=ANDESTECH.LOCAL --do
main=ANDESTECH \

```

Figure 7

Evidencia de ejecución del control A.5.15: corrección de la resolución de nombres (/etc/hosts) e inicio del aprovisionamiento del dominio ANDESTECH.LOCAL.

```

# Endurecer la politica de contraseñas del dominio en el controlador AD
sudo samba-tool domain passwordsettings set \
    --complexity=on --min-pwd-length=12 \
    --history-length=24 --max-pwd-age=90
Password complexity activated!
Password history length changed!
Minimum password length changed!
Maximum password age changed!
All changes applied successfully!

# Verificar la politica aplicada
sudo samba-tool domain passwordsettings show
Password information for domain 'DC=andestech,DC=local'

```

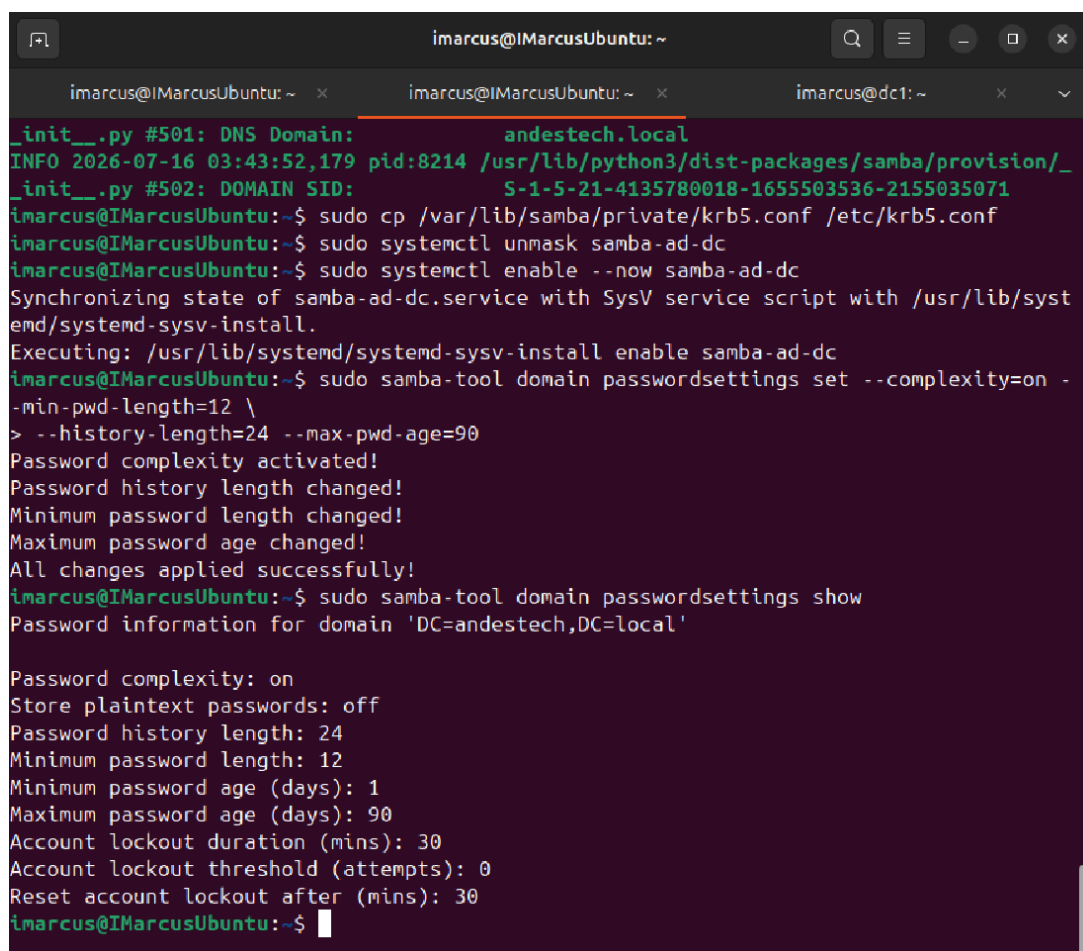
```

Password complexity: on
Store plaintext passwords: off
Password history length: 24
Minimum password length: 12
Minimum password age (days): 1
Maximum password age (days): 90
Account lockout duration (mins): 30
Account lockout threshold (attempts): 0
Reset account lockout after (mins): 30

```

Código 3

Endurecimiento de la política de contraseñas del dominio (control A.5.15).



```

imarcus@IMarcusUbuntu: ~
imarcus@IMarcusUbuntu: ~
imarcus@dc1: ~
_init__.py #501: DNS Domain: andestech.local
INFO 2026-07-16 03:43:52,179 pid:8214 /usr/lib/python3/dist-packages/samba/provision/_
_init__.py #502: DOMAIN SID: S-1-5-21-4135780018-1655503536-2155035071
imarcus@IMarcusUbuntu:~$ sudo cp /var/lib/samba/private/krb5.conf /etc/krb5.conf
imarcus@IMarcusUbuntu:~$ sudo systemctl unmask samba-ad-dc
imarcus@IMarcusUbuntu:~$ sudo systemctl enable --now samba-ad-dc
Synchronizing state of samba-ad-dc.service with SysV service script with /usr/lib/syst
emd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable samba-ad-dc
imarcus@IMarcusUbuntu:~$ sudo samba-tool domain passwordsettings set --complexity=on -
--min-pwd-length=12 \
> --history-length=24 --max-pwd-age=90
Password complexity activated!
Password history length changed!
Minimum password length changed!
Maximum password age changed!
All changes applied successfully!
imarcus@IMarcusUbuntu:~$ sudo samba-tool domain passwordsettings show
Password information for domain 'DC=andestech,DC=local'

Password complexity: on
Store plaintext passwords: off
Password history length: 24
Minimum password length: 12
Minimum password age (days): 1
Maximum password age (days): 90
Account lockout duration (mins): 30
Account lockout threshold (attempts): 0
Reset account lockout after (mins): 30
imarcus@IMarcusUbuntu:~$

```

Figure 8

Evidencia de ejecución del control A.5.15: política de contraseñas del dominio aplicada y verificada con `samba-tool domain passwordsettings show`.

Protección de datos: Base de Datos

La base de datos corporativa se protegió (A.8.12 / PR.DS) obligando el uso de TLS y restringiendo las conexiones mediante `pg_hba.conf`, con lo que se preserva la *confidencialidad* de la información y se limita la fuga de datos. El Código 4 muestra la configuración de acceso y la comprobación de que la sesión viaja cifrada (TLSv1.3), cuya evidencia de ejecución se presenta en la Figura 9.

```
# /etc/postgresql/16/main/pg_hba.conf -- solo conexiones cifradas (TLS
)
# TYPE          DATABASE    USER        ADDRESS            METHOD
hostssl        corp_db     app_user    127.0.0.1/32      scram-sha-256
hostssl        corp_db     app_user    ::1/128            scram-sha-256
hostnossl      corp_db     app_user    127.0.0.1/32      reject

# Activar TLS en el servidor y crear la base y el rol de aplicacion
sudo -u postgres psql -c "ALTER SYSTEM SET ssl = on;"
ALTER SYSTEM
sudo -u postgres psql -c "CREATE ROLE app_user LOGIN PASSWORD '
    algo_seguro';"
CREATE ROLE
sudo -u postgres psql -c "CREATE DATABASE corp_db OWNER app_user"
CREATE DATABASE

# Comprobar que la sesion viaja cifrada
psql "host=127.0.0.1 dbname=corp_db user=app_user sslmode=require" -c "\
    conninfo"
You are connected to database "corp_db" as user "app_user" on host "
    127.0.0.1" at port "5432".
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384,
    compression: off)
```

Código 4

Acceso cifrado y restringido a la base de datos PostgreSQL (control A.8.12).


```

"""

with conn.cursor() as cur:
    cur.execute(
        "SELECT id, nombre FROM clientes WHERE correo = %s",
        (correo,),
        # parametro enlazado, no
        # interpolado
    )
    return cur.fetchone()

# Version vulnerable que se descarto (concatena la entrada del usuario):
# cur.execute("SELECT id, nombre FROM clientes WHERE correo = '" + correo
# + "'")

```

Código 5

Consulta parametrizada para prevenir inyección SQL (control A.8.28).

```

imarcus@IMarcusUbuntu: ~
imarcus@IMarcusUbuntu: ~
imarcus@IMarcusUbuntu:~$ python3 -m venv venv
imarcus@IMarcusUbuntu:~$ source venv/bin/activate
(venv) imarcus@IMarcusUbuntu:~$ sudo apt install -y python3-pip && pip3 install psycopg2-binary
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
python3-pip is already the newest version (24.0+dfsg-1ubuntu1.3).
0 upgraded, 0 newly installed, 0 to remove and 220 not upgraded.
Collecting psycopg2-binary
  Downloading psycopg2_binary-2.9.12-cp312-cp312-manylinux2014_x86_64.manylinux_2_17_x86_64.whl.metadata (4.9 kB)
  Downloading psycopg2_binary-2.9.12-cp312-cp312-manylinux2014_x86_64.manylinux_2_17_x86_64.whl (4.3 MB)
    4.3/4.3 MB 32.7 MB/s eta 0:00:00
Installing collected packages: psycopg2-binary
Successfully installed psycopg2-binary-2.9.12
(venv) imarcus@IMarcusUbuntu:~$ sudo -u postgres psql corp_db -c "CREATE TABLE clientes(id serial PRIMARY KEY, nombre text, correo text);"
CREATE TABLE
(venv) imarcus@IMarcusUbuntu:~$ sudo -u postgres psql corp_db -c "INSERT INTO clientes(nombre, correo) VALUES ('Ana Perez', 'ana@andestech.ec');"
INSERT 0 1
(venv) imarcus@IMarcusUbuntu:~$ nano app/consultas.py
(venv) imarcus@IMarcusUbuntu:~$ mkdir app
(venv) imarcus@IMarcusUbuntu:~$ nano app/consultas.py
(venv) imarcus@IMarcusUbuntu:~$ python app/consultas.py
(venv) imarcus@IMarcusUbuntu:~$ cat app/consultas.py
import psycopg2

def buscar_cliente(conn, correo: str):
    with conn.cursor() as cur:
        cur.execute(
            "SELECT id, nombre FROM clientes WHERE correo = %s",
            (correo,),
        )
    return cur.fetchone()
(venv) imarcus@IMarcusUbuntu:~$

```

Figure 10

Evidencia de ejecución del control A.8.28: creación de la tabla `clientes`, inserción de un registro de prueba e implementación de la consulta parametrizada en `app/consultas.py`.

Monitoreo continuo del acceso remoto

Como control *detectivo* (A.6.7 / DE.CM) se habilitó `fail2ban` para vigilar el acceso remoto: monitorea el registro de autenticación (`/var/log/auth.log`) y, cuando una dirección supera el umbral de intentos fallidos (`maxretry`), la bloquea de forma automática con `iptables` y deja constancia en el log de auditoría. Para provocar la detección se simuló un ataque de fuerza bruta con seis intentos de inicio de sesión SSH usando un usuario inexistente, como muestra el Código 6 y evidencia la Figura 11. La Figura 12 esquematiza el procedimiento completo de detección y bloqueo.

```

# Simulación de fuerza bruta: 6 intentos de acceso SSH con un usuario
  invalido
for i in {1..6}; do ssh usuariofalso@127.0.0.1 -o

```



```

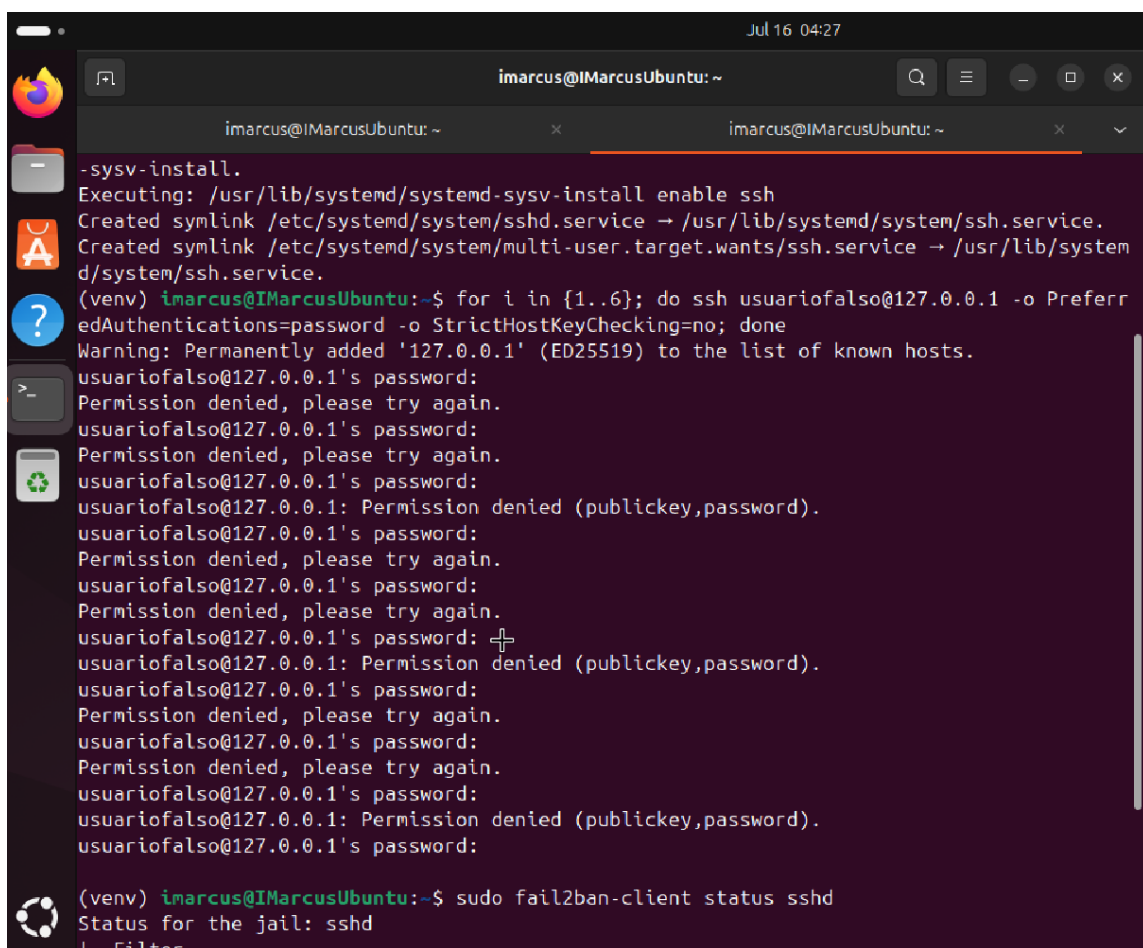
    PreferredAuthentications=password -o StrictHostKeyChecking=no; done
usuariofalso@127.0.0.1's password:
Permission denied, please try again.
usuariofalso@127.0.0.1's password:
usuariofalso@127.0.0.1: Permission denied (publickey,password).
...

# Consultar la jaula de fail2ban que vigila /var/log/auth.log
sudo fail2ban-client status sshd
Status for the jail: sshd

```

Código 6

Simulación de fuerza bruta y detección con fail2ban (control A.6.7).



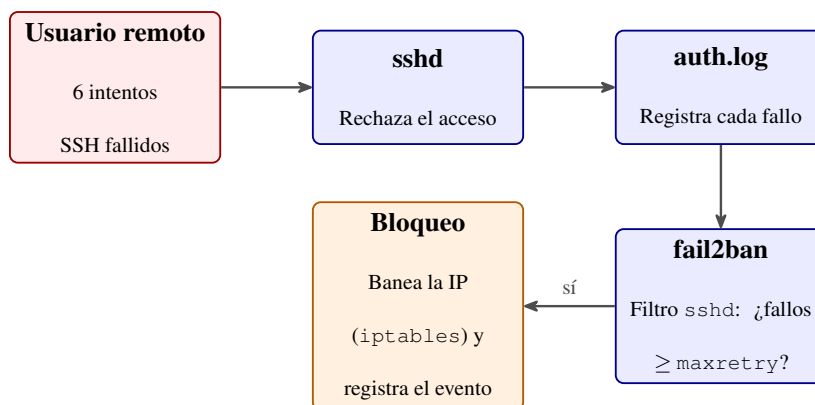
```

imarcus@IMarcusUbuntu: ~
-ysysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable ssh
Created symlink /etc/systemd/system/sshd.service → /usr/lib/systemd/system/ssh.service.
Created symlink /etc/systemd/system/multi-user.target.wants/ssh.service → /usr/lib/systemd/system/ssh.service.
(venv) imarcus@IMarcusUbuntu:~$ for i in {1..6}; do ssh usuariofalso@127.0.0.1 -o PreferredAuthentications=password -o StrictHostKeyChecking=no; done
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
usuariofalso@127.0.0.1's password:
Permission denied, please try again.
usuariofalso@127.0.0.1's password:
Permission denied, please try again.
usuariofalso@127.0.0.1's password:
usuariofalso@127.0.0.1: Permission denied (publickey,password).
usuariofalso@127.0.0.1's password:
Permission denied, please try again.
usuariofalso@127.0.0.1's password:
Permission denied, please try again.
usuariofalso@127.0.0.1's password:
usuariofalso@127.0.0.1: Permission denied (publickey,password).
usuariofalso@127.0.0.1's password:
Permission denied, please try again.
usuariofalso@127.0.0.1's password:
Permission denied, please try again.
usuariofalso@127.0.0.1's password:
usuariofalso@127.0.0.1: Permission denied (publickey,password).
usuariofalso@127.0.0.1's password:
(venv) imarcus@IMarcusUbuntu:~$ sudo fail2ban-client status sshd
Status for the jail: sshd

```

Figure 11

Evidencia de ejecución del control A.6.7: simulación de un ataque de fuerza bruta (seis intentos SSH fallidos) y consulta del estado de la jaula sshd de fail2ban.

**Figure 12**

Esquema del procedimiento de detección y bloqueo del control A.6.7: los intentos fallidos de SSH quedan en *auth.log*, *fail2ban* los correlaciona y, al superar el umbral, bloquea la dirección de origen.

Respaldo y recuperación

Finalmente, como control *correctivo* (A.8.13 / RC.RP) se diseñó el procedimiento de respaldo cifrado de la base de datos y su restauración en un entorno de prueba aislado, que garantiza la *disponibilidad* de la información ante un incidente. El Código 7 documenta el procedimiento propuesto —respaldo, recuperación y verificación de integridad del dato restaurado—, cuyo flujo se esquematiza en la Figura 13.

```

# Respaldo cifrado de la base de datos corporativa
sudo -u postgres pg_dump corp_db | gpg --symmetric --cipher-algo AES256
\
-o /respaldos/corp_db_$(date +%F).sql.gpg

# Recuperacion ante desastre en un entorno de prueba aislado
sudo -u postgres createdb corp_db_restore
gpg --decrypt /respaldos/corp_db_$(date +%F).sql.gpg | sudo -u postgres
psql corp_db_restore

# Verificar la integridad del dato restaurado
sudo -u postgres psql -d corp_db_restore -c "SELECT count(*) FROM
clientes;"
  
```

Código 7

Procedimiento de respaldo cifrado y recuperación de la base de datos (control A.8.13).

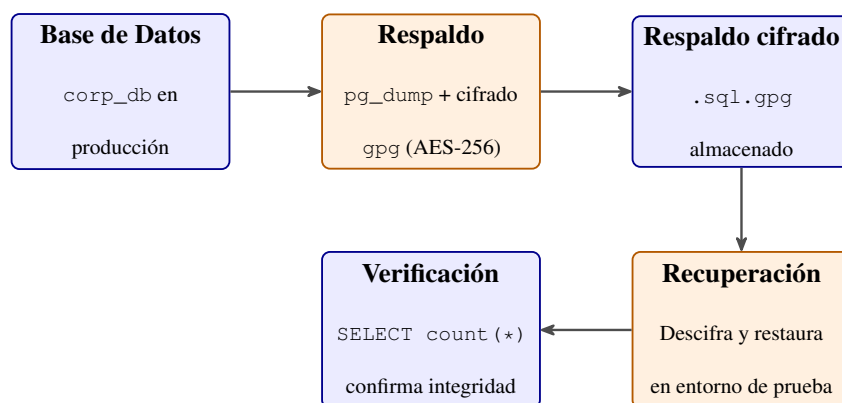


Figure 13

Esquema del procedimiento del control correctivo A.8.13: la base de datos se respalda cifrada, y ante un incidente se restaura en un entorno de prueba donde se verifica la integridad del dato recuperado.

La implementación simulada evidencia la complementariedad de ambos marcos: cada control técnico de ISO/IEC 27002 (columna derecha de la Tabla 6) materializa un resultado esperado del NIST CSF 2.0 (columna central), y el conjunto cubre los tres tipos de control —preventivo, detectivo y correctivo— sobre las tres propiedades de la tríada CIA. De este modo, el escenario de AndesTech S.A. no queda protegido por un marco aislado, sino por la traducción de los resultados de gobernanza del CSF 2.0 en salvaguardas técnicas verificables de ISO/IEC 27002:2022.

Análisis Crítico

La lectura habitual de esta comparación concluye que ambos marcos son complementarios y que basta con adoptarlos en conjunto. Esa conclusión, no obstante, oculta el costo real de la integración. Mantener el CSF 2.0 y la ISO/IEC 27002:2022 en paralelo implica documentación duplicada, dos vocabularios de riesgo que traducir de forma constante y un mapeo entre funciones y controles que se degrada con cada nueva versión de cualquiera de los dos marcos. Para una organización con recursos limitados —como la PyME o la institución pública del escenario— esa duplicidad puede derivar en *security theater*: abundante evidencia documental y escasa reducción efectiva del riesgo. La complementariedad, por tanto, no es gratuita; es una decisión de ingeniería con sobrecarga de gobernanza que la literatura comparativa rara vez cuantifica (Sulistiyowati, Handayani, et al., 2021).

Un examen más incómodo muestra que las virtudes más citadas de cada marco son,

al mismo tiempo, sus mayores riesgos. La flexibilidad del CSF 2.0 —su negativa a prescribir cómo alcanzar los resultados— es también una puerta de escape: una organización inmadura puede declararse alineada al CSF mientras implementa controles mínimos, porque nadie verifica el cómo. La misma libertad que abarata el inicio abarata también el simulacro. De forma simétrica, la certificabilidad que se vende como la gran ventaja de ISO 27001/27002 introduce un incentivo perverso: el certificado es una fotografía de un instante, obtenida para aprobar una auditoría, mientras que el atacante opera de forma continua; optimizar para el auditor no es optimizar para la seguridad. A ello se añade que la norma es de pago, lo que excluye de origen a las organizaciones pequeñas que más necesitarían su guía (ISO/IEC, 2022b).

Incluso la innovación más celebrada del CSF 2.0, la función Govern, admite una lectura distinta: más que un avance original, representa el reconocimiento de que las versiones previas carecían de la capa de gobernanza que la familia ISO/IEC 27000 incorporó desde su concepción a través del SGSI. Govern no adelanta a ISO; la alcanza (Pascoe et al., 2024). Esta perspectiva desactiva la falsa disyuntiva de enfrentar el CSF con la ISO: no se comparan dos competidores equivalentes, sino un lenguaje de resultados y un catálogo de controles; preguntar cuál es mejor equivale a comparar un índice con los capítulos que ese índice organiza.

La conclusión honesta para el escenario de AndesTech S.A. no es adoptar ambos, sino secuenciarlos y vigilar el riesgo que ninguno de los dos elimina. Un marco no vuelve segura a una organización: la vuelve *legible* ante auditores, directivos y reguladores, y la seguridad real es, en el mejor de los casos, un subproducto. Lo demostró el propio caso práctico: los controles que de verdad frenaron un ataque —la política `drop` del firewall y el bloqueo de `fail2ban`— operan por debajo del nivel de abstracción de ambos marcos; el marco los nombra y los ordena, pero no los ejecuta. Por eso el mayor peligro para AndesTech no es elegir el marco equivocado, sino confundir la adopción de un marco con estar protegida (Risk Publishing, 2026).

Conclusiones

A continuación se responden las preguntas guía del taller. Las respuestas evitan el consenso fácil y priorizan las tensiones y desventajas que cada elección arrastra, por ser ahí

—y no en las virtudes evidentes— donde reside el verdadero criterio de decisión.

¿Cuál marco está más orientado hacia la gestión?

El NIST CSF 2.0, por su función Govern y su modelo de Tiers. Conviene, sin embargo, matizar qué significa esa orientación: gestionar es precisamente *no* ejecutar. La fortaleza gerencial del CSF es indisociable de su vacío operativo —administra, comunica y prioriza un riesgo cuyos controles técnicos debe tomar prestados de otros catálogos—. Está más orientado a la gestión, sí, porque delega todo lo demás.

¿Cuál posee mayor detalle en controles?

La ISO/IEC 27002:2022, con sus 93 controles, propósito y cinco atributos. Pero mayor detalle no equivale a mayor seguridad: un catálogo minucioso invita al cumplimiento por lista de verificación y envejece con la tecnología que describe. El detalle rinde solo si la organización tiene la madurez para contextualizarlo; sin ella, se convierte en un exceso que abruma y en una falsa sensación de exhaustividad.

¿Cuál es más sencillo para comenzar un programa de ciberseguridad?

El NIST CSF 2.0, por su gratuidad y baja curva de aprendizaje. La paradoja es que esa facilidad proviene de no decir qué hacer, y para un equipo sin experiencia en seguridad la ausencia de prescripción produce parálisis por decisión. Para quien carece de recursos, una lista prescriptiva (ISO o CIS) puede resultar más sencilla de ejecutar que un marco abierto: empezar es barato, hacerlo bien no lo es.

¿Cuál facilita una certificación?

La ISO/IEC 27002 junto con ISO 27001 es la única vía certificable; el CSF no certifica. Ahora bien, la certificación facilita *demostrar* seguridad, no necesariamente *tenerla*: acredita un instante, exige auditorías de mantenimiento y un ciclo PHVA vivo, y un certificado que caduca por falta de sostenimiento es peor que no haberlo tenido, porque genera una expectativa que la organización ya no cumple (ISO/IEC, 2022a).

¿Cuál se considera más apropiado para una institución pública ecuatoriana?

La respuesta convencional es ISO 27001/27002 por su reconocimiento internacional. El contexto ecuatoriano invita a matizarla: presupuestos ajustados, alta rotación de personal técnico y una cultura de SGSI aún incipiente hacen que una certificación costosa y no

sostenida caduque y se convierta en pasivo. Resulta más defendible una secuencia inversa a la habitual: iniciar con el CSF 2.0 —gratuito y gradual— para construir la cultura y las métricas de gobernanza, y reservar la certificación ISO como meta una vez que el SGSI sea sostenible, no como punto de partida.

¿Cuál sería más apropiado para una PyME?

Por sí sola, la PyME encontraría en el CSF 2.0 la opción gratuita y flexible. Pero la elección rara vez depende de los méritos del marco: una PyME que sea proveedora de una empresa grande será obligada por contrato o por exigencias de la cadena de suministro a exhibir ISO 27001, y entonces el CSF “gratuito” se revela como una falsa economía que pagará más tarde. El mercado, no la técnica, suele decidir el marco de una PyME.

¿Cómo podrían integrarse ambos marcos dentro de un SGSI?

El patrón es CSF 2.0 como capa de gobernanza e ISO 27002 como implementación técnica, unidos por los atributos de la norma. La advertencia menos evidente es que ese enlace no es una tabla que se dibuja una vez: la correspondencia es de muchos a muchos y se degrada con cada revisión de los marcos. Integrar exige designar cuál de los dos es la “fuente de verdad” documental y asumir el mantenimiento del mapeo como una tarea permanente, no como un anexo (ISO/IEC, 2022b).

¿Cuál marco ofrece mayor flexibilidad?

El CSF 2.0, sin discusión. Conviene ver el reverso: flexibilidad y verificabilidad están en tensión. Cuanto menos prescribe un marco, menos comparables son dos implementaciones suyas y más difícil resulta demostrar que se hizo lo correcto. La flexibilidad del CSF traslada la carga de la prueba a la propia organización; es libertad a cambio de responsabilidad.

¿Cuál proporciona mayor profundidad en controles?

La ISO/IEC 27002:2022, por la granularidad de sus 93 controles. Esa profundidad, sin embargo, es estática frente a amenazas dinámicas: un catálogo cerrado en 2022 ya envejece ante los vectores de 2026 —inteligencia artificial ofensiva, cadenas de suministro de software—, y la profundidad documental no implica profundidad en la implementación real. La ventaja se sostiene solo con una cadencia de actualización que la propia periodicidad de la norma dificulta.

¿En qué casos conviene utilizar ambos?

La respuesta usual —organizaciones medianas y grandes con exposición regulatoria— es correcta pero incompleta. Usar ambos solo rinde por encima de cierto umbral de madurez y de una dotación de personal capaz de absorber la sobrecarga de gobernanza; por debajo de ese umbral, mantener dos marcos genera contradicción y simulacro en lugar de sinergia. El criterio, pues, no es el tamaño sino la madurez: primero la capacidad de sostenerlos, después la decisión de sumarlos.

¿Qué aprendió el grupo durante el análisis?

Más allá de la complementariedad, el grupo aprendió que un marco no vuelve segura a una organización, sino *legible* ante auditores y directivos, y que la seguridad efectiva es un subproducto que puede o no aparecer. El propio desarrollo lo evidenció: la distancia entre la tabla de mapeo, limpia y ordenada, y la máquina real —con errores de resolución de nombres, fallos de sintaxis y registros incompletos— es donde de verdad se juega la seguridad, y es justo lo que ambos marcos abstraen. El aprendizaje central fue desconfiar de la ecuación “marco adoptado = organización protegida”.

¿Qué marco se recomendaría implementar en la organización propuesta?

Para AndesTech S.A. se recomienda una adopción *secuenciada*, no simultánea, y con una condición de parada explícita. Primero, el CSF 2.0 para instalar la gobernanza y las métricas de riesgo, junto con la implementación efectiva de los controles técnicos demostrados en el caso práctico (firewall, VPN, endurecimiento de identidades, cifrado y monitoreo). Después, y solo cuando el SGSI sea sostenible sin depender de un esfuerzo heroico puntual, la certificación ISO 27001. La recomendación incluye su propio criterio de fracaso: si la organización acumula documentación de ambos marcos sin que los controles operen y se verifiquen, debe detenerse, porque estará produciendo un simulacro de seguridad en lugar de seguridad.

Recomendaciones

A partir del análisis comparativo, se plantean las siguientes recomendaciones para la adopción de marcos de ciberseguridad en la organización propuesta y en escenarios similares:

- **Iniciar con un diagnóstico basado en Perfiles del CSF 2.0.** Elaborar el perfil actual y el perfil objetivo de la organización permite identificar brechas y priorizar inversiones

antes de comprometer recursos en una implementación formal de controles (Pascoe et al., 2024).

- **Adoptar una estrategia integrada en lugar de un marco único.** Usar el CSF 2.0 como capa de gobernanza y comunicación con la alta dirección, y la ISO/IEC 27002:2022 como catálogo de implementación técnica dentro de un SGSI, aprovecha las fortalezas de cada marco y evita las limitaciones de una adopción aislada (Sulistiyowati, Handayani, et al., 2021).
- **Aprovechar los atributos de los controles ISO 27002 para el mapeo entre marcos.** Los atributos de concepto de ciberseguridad de la norma se corresponden con las funciones del CSF, lo que reduce el esfuerzo de trazabilidad cuando se mantienen ambos marcos en paralelo (ISO/IEC, 2022b).
- **Formalizar el SGSI bajo ISO/IEC 27001 si se requiere certificación.** Para organizaciones con exposición regulatoria o contractual, la certificación ISO 27001 aporta la evidencia verificable frente a terceros que el CSF 2.0 no puede ofrecer (ISO/IEC, 2022a).
- **Complementar los resultados del CSF con catálogos de controles detallados.** Cuando la organización necesite mayor granularidad técnica que la de ISO 27002, el catálogo NIST SP 800-53 ofrece salvaguardas específicas de seguridad y privacidad ya mapeadas con el CSF (Joint Task Force Interagency Working Group, 2020).
- **Revisar el programa con el ciclo PHVA.** Cualquiera que sea la combinación adoptada, la mejora continua exige auditorías internas periódicas, métricas de cumplimiento y actualización de la política ante cambios en las amenazas o en la infraestructura (Anonymous, 2026).

Referencias

- Anonymous. (2026). Operationalising information security management: A procedural framework analysis of ISO/IEC 27001:2022 implementation in a financial-technology organisation [Acceso libre, preprint arXiv:2604.23230]. <https://arxiv.org/abs/2604.23230>
- Ebers, M., et al. (2024). From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models [Acceso libre, preprint arXiv:2402.15770]. <https://arxiv.org/abs/2402.15770>
- ISO Library. (2024). ISO/IEC 27002: Information security, cybersecurity and privacy protection — security controls [Acceso libre]. <https://iso-library.com/standard/27002/>
- ISO/IEC. (2022a). *ISO/IEC 27001:2022 — information security, cybersecurity and privacy protection — information security management systems — requirements*. International Organization for Standardization. <https://www.iso.org/standard/27001>
- ISO/IEC. (2022b). *ISO/IEC 27002:2022 — information security, cybersecurity and privacy protection — information security controls*. International Organization for Standardization. <https://www.iso.org/standard/75652.html>
- Joint Task Force Interagency Working Group. (2020). Security and privacy controls for information systems and organizations. NIST SP 800-53 Rev. 5 [Acceso libre]. <https://doi.org/10.6028/NIST.SP.800-53r5>
- Léveillé, D., & Jaskolka, J. (2025). A scalable game-theoretic approach for selecting security controls from standardized catalogues [Acceso libre, preprint arXiv:2503.15626]. <https://arxiv.org/abs/2503.15626>
- Modi, A., Kuzminykh, I., & Ghita, B. (2023). Data driven approaches to cybersecurity governance for board decision-making — a systematic review [Acceso libre, preprint arXiv:2311.17578]. <https://arxiv.org/abs/2311.17578>
- Pascoe, C., Quinn, S., & Scarfone, K. (2024). *The NIST cybersecurity framework (CSF) 2.0* (tech. rep. No. CSWP 29) (Acceso libre). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>

Risk Publishing. (2026). NIST CSF vs ISO 27001: Which cybersecurity framework is right for your organization? [Acceso libre]. <https://riskpublishing.com/nist-csf-vs-iso-27001-which-cybersecurity/>

Sulistyowati, D., Handayani, F., et al. (2021). Comparative analysis and design of cybersecurity maturity assessment methodology using NIST CSF, COBIT, ISO/IEC 27002 and PCI DSS [Acceso libre vía Semantic Scholar]. *Proceedings of ICORIS 2021*. <https://www.semanticscholar.org/paper/Comparative-Analysis-and-Design-of-Cybersecurity-Sulistyowati-Handayani/3659b7e383717185c191fa9bbb6f874dc0a58519>